



THE COMPLETE ENTERPRISE IAM & PAM MASTER GUIDE

Identity & Access Management | Privileged Access Management

Modern Identity Security for Cloud-First Enterprises

Zero Trust Architecture • Cloud IAM • PAM Engineering • IGA • DevSecOps
Authentication Protocols • Authorization Frameworks • Compliance • AI/ITDR

Table of Contents

Sr. No.	Section Heading	Page No.
1	Executive Overview	3
2	Foundations of Identity Security	5
3	Authentication Architecture	13
4	Authorization & Access Control	20
5	Privileged Access Management (PAM)	31
6	Identity Governance & Administration (IGA)	34
7	Cloud IAM (Modern Cloud-First Security)	48
8	DevSecOps & Machine Identity	40
9	Zero Trust & Modern Security Architecture	43
10	IAM/PAM Attacks & Defensive Security	47
11	Compliance, Risk & Regulatory Frameworks	49
12	IAM/PAM Program Management & Leadership	53
13	Identity Threat Detection & Response (ITDR)	55
14	The Future of Identity Security	57
15	References	61

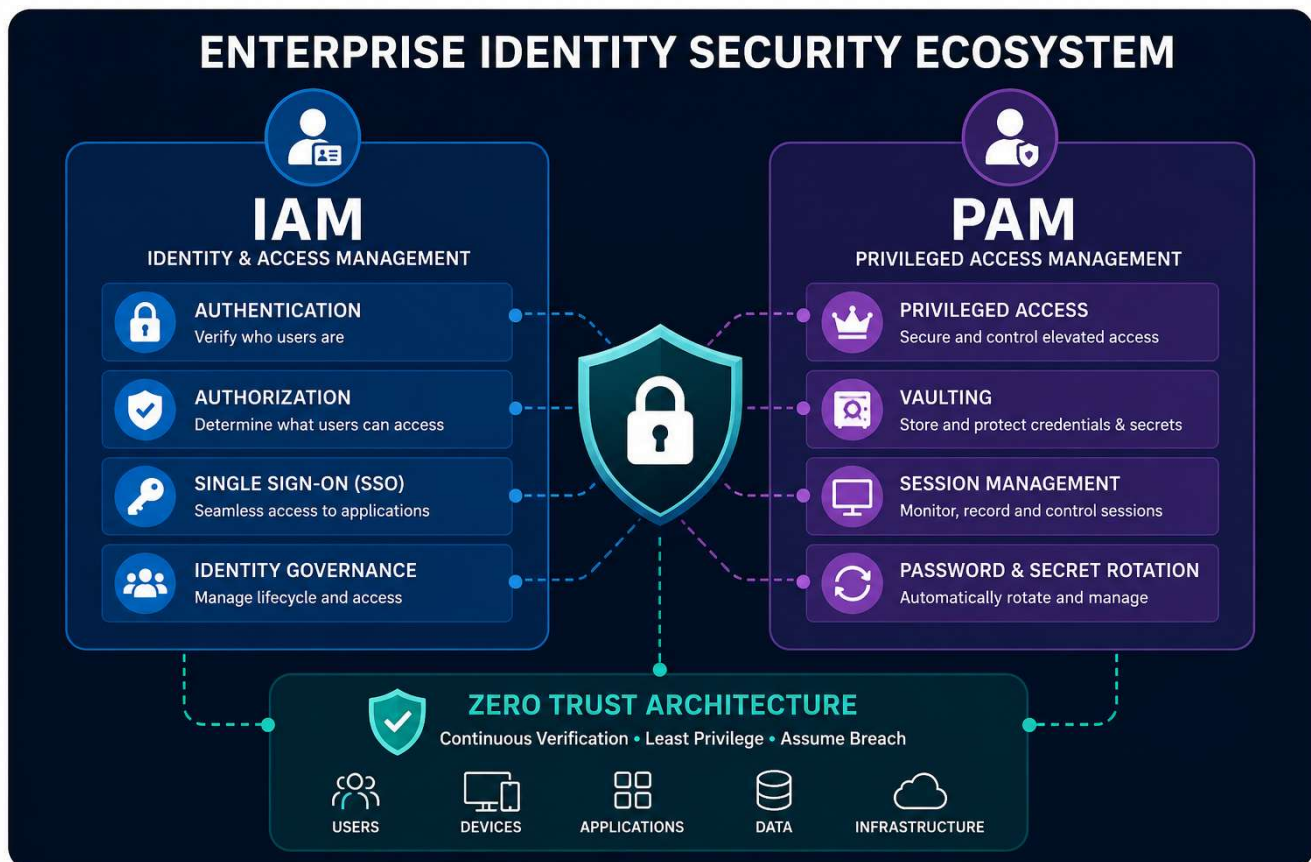
EXECUTIVE OVERVIEW

Identity has become the new security perimeter. In today's cloud-native, hybrid, and distributed enterprise environments, the traditional network boundary has collapsed. Adversaries no longer 'hack in' — they log in. The compromise of a single privileged credential can cascade into a full enterprise breach, ransomware deployment, or cloud-wide data exfiltration event.

This guide represents a comprehensive, technically rigorous reference for Identity and Access Management (IAM) and Privileged Access Management (PAM) — covering foundational concepts through advanced enterprise implementation, modern cloud architectures, attack methodologies, defensive engineering, governance frameworks, and operational leadership.

Who This Guide Is For

- IAM Engineers and Architects designing or maturing enterprise identity programs
- PAM Engineers deploying CyberArk, BeyondTrust, Delinea, or cloud-native PAM solutions
- Cloud Security Engineers working with AWS IAM, Azure Entra ID, or Google Cloud IAM
- SOC Analysts detecting identity-based attacks and anomalous access patterns
- Security Architects integrating IAM into Zero Trust and DevSecOps programs
- IAM/PAM Managers owning identity governance programs, teams, and executive reporting
- Cybersecurity professionals pursuing certifications such as SC-300, AZ-500, CISSP, or CCSP



Scope of Coverage

Domain	Coverage
Identity Foundations	Digital identity types, lifecycle, directory services, protocols
Authentication Architecture	MFA, FIDO2, Passkeys, Adaptive Auth, Protocols (SAML, OIDC, OAuth 2.0)
Authorization & Access Control	RBAC, ABAC, PBAC, JIT, JEA, PoLP, SoD
Privileged Access Management	Vaulting, session recording, secrets mgmt, PAM architectures
Identity Governance & Administration	IGA, Joiner-Mover-Leaver, access reviews, SailPoint, Saviynt
Cloud IAM	AWS IAM, Azure Entra ID, GCP IAM, Kubernetes RBAC, Multi-cloud
DevSecOps & Machine Identity	Secrets management, CI/CD identity, SPIFFE/SPIRE, workload federation
Zero Trust Architecture	NIST ZTA, continuous verification, identity-centric controls
Attack & Defense	Kerberoasting, Golden Ticket, OAuth abuse, token theft, MFA fatigue
Compliance & Governance	ISO 27001, NIST, SOC 2, PCI-DSS, HIPAA, GDPR
IAM/PAM Management	Technical playbook, KPIs, team structure, program ownership
AI & Future of IA	ITDR, autonomous identity, decentralized identity, passwordless

SECTION 1 — FOUNDATIONS OF IDENTITY SECURITY

1.1 What Is Digital Identity

A digital identity is a collection of attributes, credentials, and contextual signals that uniquely represent an entity — whether human or machine — within an information system or across federated environments. Understanding identity types is foundational to designing any effective IAM program.

1.1.1 Identity Types

User Identity

Represents a human individual interacting with systems. This includes employees, contractors, partners, and customers. User identities are typically stored in directory services such as Active Directory or Okta Universal Directory and are associated with authentication credentials, group memberships, and role assignments.

Machine Identity

Represents non-human entities such as servers, workstations, IoT devices, and network appliances. Machine identities are authenticated using certificates (X.509), API keys, or SSH keys. The proliferation of cloud infrastructure has caused machine identities to dramatically outnumber human identities in most enterprises.

Service Identity

Represents software services, daemons, or application components that need to authenticate to other services or systems. Service identities use service accounts, managed identities (Azure), service accounts (GCP/Kubernetes), or IAM roles (AWS) to obtain access without human intervention.

Device Identity

Represents endpoint devices — laptops, mobile phones, tablets — that are registered and managed within an enterprise. Device identity is central to Zero Trust architectures where device health and compliance state are evaluated as part of access decisions (e.g., Intune MDM compliance, CrowdStrike sensor status).

Workload Identity

Represents compute workloads such as VMs, containers, serverless functions, and Kubernetes pods. Workload identity federation (WIF) allows workloads to authenticate using short-lived, cryptographically bound tokens rather than long-lived static credentials. AWS IAM Roles for EC2, Azure Managed Identities, and GCP Workload Identity Federation are examples.

Non-Human Identity (NHI)

A broad category encompassing all identity types that are not directly operated by a human in real time: bots, scripts, CI/CD pipelines, RPA agents, APIs, and integrations. NHIs represent

the fastest-growing attack surface in modern enterprises and require dedicated lifecycle governance.

Identity Type	Examples	Authentication Mechanism	Primary Risk
User	Employee, contractor, admin	Password + MFA, SSO	Credential theft, phishing
Machine	Server, IoT device, endpoint	X.509 certificates, SSH keys	Certificate mismanagement
Service	Application, daemon, API	Service account, managed identity	Over-provisioned service accounts
Device	Laptop, mobile, workstation	Device certificate, MDM attestation	Unmanaged device access
Workload	VM, container, Lambda, pod	IAM role, workload identity token	Privilege escalation via role chaining
Non-Human	Bot, CI/CD pipeline, RPA	API key, OAuth token, secret	Secret sprawl, hardcoded credentials

1.1.2 Identity as the New Security Perimeter

The traditional 'castle-and-moat' security model assumed a trusted internal network. Perimeter firewalls, VPNs, and network segmentation were the primary controls. Cloud adoption, remote work, SaaS proliferation, and API-driven architectures have dismantled this assumption entirely.

Today, an adversary who obtains valid credentials can authenticate from anywhere in the world and access cloud resources without ever touching a network perimeter. The 2020 SolarWinds breach, the 2021 Colonial Pipeline attack, the 2023 Microsoft Cloud breach — all exploited identity weaknesses, not firewall gaps.

- Over 80% of data breaches involve compromised credentials (Verizon DBIR 2024)
- Cloud environments have on average 12x more entitlements than are actually used (Gartner)
- Service account and NHI credentials account for the majority of lateral movement paths
- Identity-based attacks bypass traditional network and endpoint controls entirely

[i] Identity is not merely an IT function — it is the primary attack surface and the primary control plane in modern enterprise security.

1.2 Introduction to Identity and Access Management (IAM)

1.2.1 Definition and Core Objectives

Identity and Access Management (IAM) is the discipline, framework, and set of technologies that ensures the right entities have the right access to the right resources at the right time — and that access is continuously governed, reviewed, and audited.

IAM operates across the full identity lifecycle: from the moment an identity is provisioned through its ongoing access governance to its eventual de-provisioning. It spans human and machine identities, on-premises and cloud resources, and synchronous and asynchronous access patterns.

1.2.2 Business and Security Drivers

Driver Category	Specific Driver	IAM Response
Security	Credential-based attacks dominate breach vectors	MFA enforcement, passwordless, adaptive authentication
Security	Excessive privilege enables lateral movement	Least privilege, JIT access, access reviews
Compliance	SOX, PCI-DSS, HIPAA require access controls	Role-based access, SoD enforcement, audit trails
Operational	Employee onboarding/offboarding velocity	Automated provisioning/de-provisioning (IGA)
Cloud	Multi-cloud environments create identity sprawl	Federated identity, centralized governance
DevOps	CI/CD pipelines require machine credentials	Secrets management, workload identity federation
Regulatory	GDPR requires data access accountability	Access logging, certification campaigns, data governance
Business	Third-party/partner access expansion	B2B federation, external identity governance

1.2.3 Authentication vs. Authorization vs. Accounting (AAA)

Authentication (AuthN)

Authentication is the process of verifying that an entity is who it claims to be. It answers the question: 'Are you who you say you are?' Authentication can use factors of knowledge (passwords), possession (hardware token), inherence (biometrics), or behavioral signals. Modern authentication increasingly relies on multi-factor and risk-adaptive mechanisms.

Authorization (AuthZ)

Authorization is the process of determining what an authenticated entity is permitted to do. It answers the question: 'What are you allowed to access?' Authorization is enforced through access control models (RBAC, ABAC), policies, and entitlement engines. Authorization decisions can be static (role assignment) or dynamic (context-aware policy evaluation).

Accounting (Audit/Logging)

Accounting captures a complete record of what authenticated, authorized entities actually did. It answers the question: 'What did you do?' This includes access logs, session recordings, privileged action audit trails, and compliance evidence. Accounting is foundational for forensic investigation, compliance reporting, and anomaly detection.

1.2.4 Identity Lifecycle Management

The identity lifecycle describes the complete journey of an identity from creation to termination. Effective lifecycle management ensures that access rights are appropriate, current, and revoked when no longer needed.

Lifecycle Phase	Activities	Risks if Unmanaged
Provision (Joiner)	Account creation, role assignment, system access grants	Excessive access at creation, delayed provisioning SLA
Maintain (Mover)	Access modification on role change, department transfer, promotion	Accumulation of legacy permissions (permission creep)
Review	Periodic access certification, manager approvals, compliance attestation	Stale entitlements, orphaned accounts
De-provision (Leaver)	Account disablement, credential revocation, resource de-assignment	Active accounts for departed employees (ghost accounts)
Emergency	Break-glass access, emergency privilege elevation, incident response access	Unaudited emergency access, persistent privilege after incidents

1.3 Core IAM Components

A mature IAM architecture comprises multiple integrated layers. Understanding each component's role is essential for architecture design, vendor selection, and gap assessment.

1.3.1 Identity Repository

The identity repository is the authoritative system of record for identities and their attributes. It stores identity data including name, email, department, manager, employment status, and role assignments. Common implementations include Active Directory (on-premises), Microsoft Entra ID (cloud), Okta Universal Directory, and LDAP-based directories. The HR system (e.g., Workday, SAP SuccessFactors) typically serves as the upstream source of truth for employee identities, feeding into the identity repository via SCIM or API integration.

1.3.2 Directory Services

Directory services provide a structured, hierarchical store for identity data and enable authentication and authorization queries at scale. They expose identity data over standardized protocols (LDAP, Kerberos, SAML) and are queried by applications, PAM systems, and IGA platforms to validate identities and retrieve attributes.

1.3.3 Access Control Engine

The access control engine evaluates authorization requests against defined policies, roles, and entitlements. It receives a request (subject, action, resource, context), evaluates applicable policies, and returns a permit or deny decision. Modern access control engines support RBAC, ABAC, and PBAC models, and may integrate with external policy authorities (e.g., OPA — Open Policy Agent) for dynamic evaluation.

1.3.4 Federation Layer

The federation layer enables identity assertions to be trusted across organizational and system boundaries. It implements protocols such as SAML 2.0, OAuth 2.0, and OpenID Connect to allow users to authenticate once with their primary identity provider (IdP) and gain access to applications across multiple domains without re-authentication. Federation is foundational for SSO, B2B access, and cloud application integration.

1.3.5 Authentication Services

Authentication services enforce authentication policies, manage credential verification, and issue session tokens or security assertions. This layer includes the primary IdP (Okta, Azure Entra ID, Ping), MFA services, adaptive authentication engines, and passwordless authentication frameworks. Modern authentication services evaluate risk signals (IP reputation, device health, user behavior) to determine the required authentication strength.

1.3.6 Authorization Frameworks

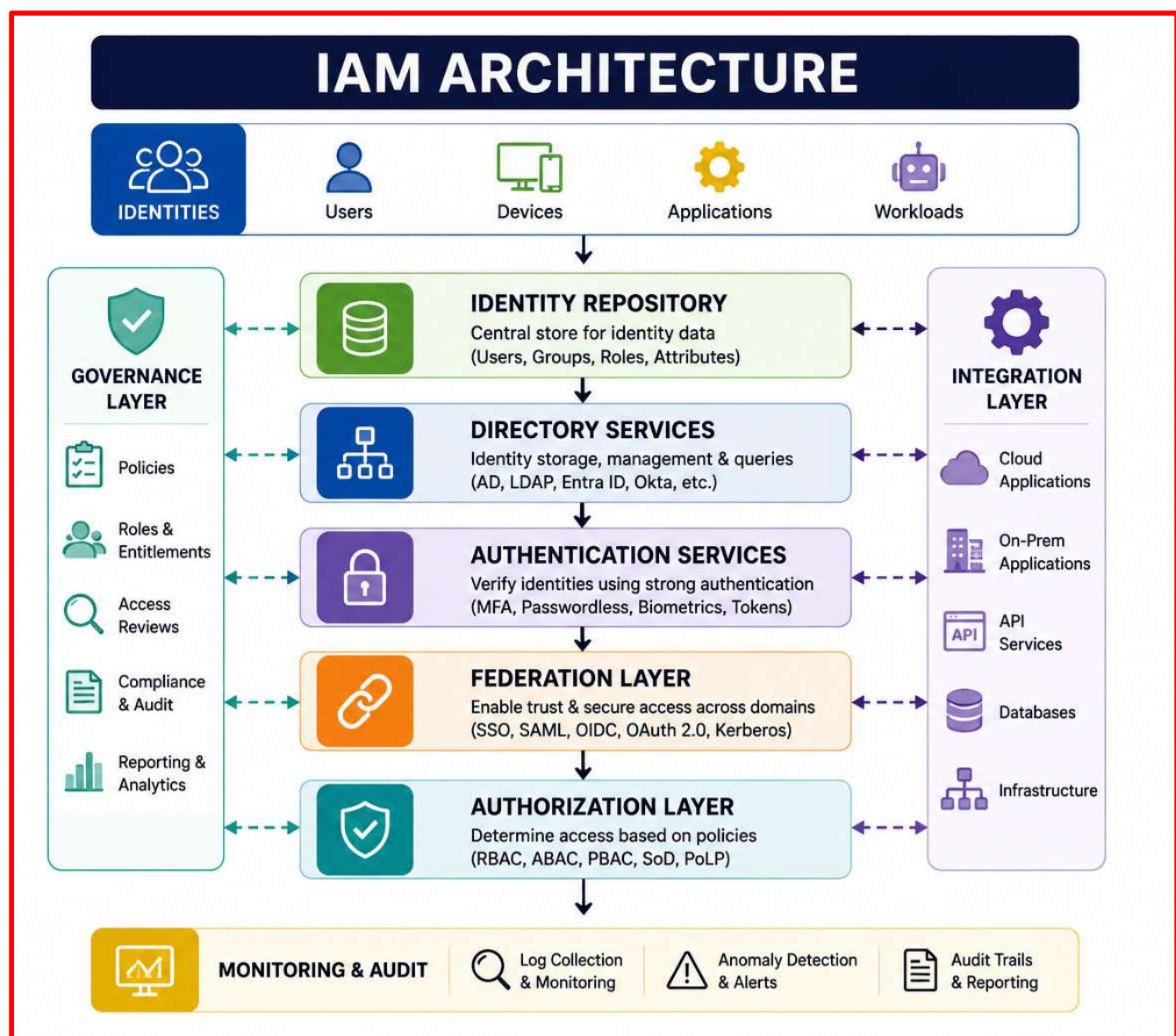
Authorization frameworks define the rules, models, and enforcement points for access control decisions. They include policy administration points (PAP) where policies are authored, policy decision points (PDP) where policies are evaluated, and policy enforcement points (PEP) where decisions are enforced. Well-architected authorization frameworks separate policy from application code, enabling centralized governance and consistent enforcement.

1.3.7 Governance Layer

The governance layer provides oversight of the entire IAM ecosystem. It encompasses identity governance and administration (IGA) platforms, access certification campaigns, role management, SoD enforcement, and policy management. The governance layer ensures that access rights are aligned with business roles, compliance requirements, and least privilege principles, and provides the audit trail required for regulatory reporting.

1.3.8 Audit and Compliance Layer

The audit and compliance layer collects, stores, and analyzes access logs, authentication events, privileged session recordings, and governance actions. It integrates with SIEM platforms (Splunk, Microsoft Sentinel) for real-time detection, and with GRC platforms for compliance reporting. This layer provides the evidence required for SOC 2, ISO 27001, PCI-DSS, HIPAA, and other regulatory frameworks.



1.4 Directory Services and Identity Stores

1.4.1 Active Directory (AD)

Microsoft Active Directory is the dominant on-premises directory service for Windows environments. AD provides authentication (Kerberos, NTLM), authorization (group policies, ACLs), directory lookup (LDAP), and certificate services (AD CS). AD organizes identities into a hierarchical structure of Forests, Domains, Organizational Units (OUs), and Groups. Group Policy Objects (GPOs) enforce security configurations at scale.

- Forest: The highest-level AD container; the security and administrative boundary
- Domain: Logical grouping of objects within a forest; shares a common namespace and authentication policy
- OU (Organizational Unit): Sub-container for organizing objects and applying GPOs
- Groups: Collections of user/computer objects for access control and policy assignment (Global, Domain Local, Universal)

⚠ Active Directory is the most targeted identity system in enterprise environments. Misconfigurations in AD trusts, delegations, and ACLs are primary paths for lateral movement and privilege escalation.

1.4.2 LDAP (Lightweight Directory Access Protocol)

LDAP is an open, vendor-neutral protocol for accessing and maintaining distributed directory information. Operating over TCP/IP (port 389 for plain, port 636 for LDAPS), LDAP queries a directory server using Distinguished Names (DN) and Object Classes. Bind operations authenticate clients; search operations query identity attributes. LDAP is widely used by Linux/Unix systems, network devices, and applications for centralized authentication.

1.4.3 Microsoft Entra ID (Azure Active Directory)

Microsoft Entra ID (formerly Azure AD) is Microsoft's cloud-native identity and access management platform. It serves as the primary IdP for Microsoft 365, Azure, and thousands of integrated SaaS applications. Unlike on-premises AD, Entra ID uses modern protocols (SAML, OIDC, OAuth 2.0) rather than Kerberos/NTLM, and manages identities in a flat tenant model rather than a hierarchical domain structure.

- Tenants: Isolated Entra ID instances representing an organization
- Conditional Access: Policy-based access control evaluating user, device, location, and risk signals
- Privileged Identity Management (PIM): Just-in-time privilege elevation with approval workflows
- External Identities (B2B/B2C): Guest user access and customer identity management
- Hybrid Identity: Azure AD Connect synchronizes on-premises AD with Entra ID

1.4.4 Okta Universal Directory

Okta Universal Directory is a cloud-based identity store that aggregates and normalizes identity data from multiple sources (HR systems, AD, LDAP, databases) into a unified profile. It supports flexible schema extension, group management, and profile mastering — designating

which source is authoritative for each attribute. Okta serves as the hub for SSO, MFA, and lifecycle management across cloud and on-premises applications.

1.4.5 On-Premises vs. Cloud Identity Architecture

Dimension	On-Premises (AD/LDAP)	Cloud Identity (Entra ID / Okta)
Protocol	Kerberos, NTLM, LDAP	SAML, OIDC, OAuth 2.0, SCIM
Network dependency	Requires domain connectivity	Internet-accessible; no VPN required
Scalability	Requires DC infrastructure planning	Elastic, globally distributed
MFA	Requires additional server (NPS, MFA Server)	Native, cloud-delivered MFA
Conditional Access	GPO-based, limited context	Rich policy engine with device/risk signals
Machine management	Group Policy, WSUS	Intune MDM/MAM, Autopilot
Hybrid integration	N/A (native)	Azure AD Connect, SCIM provisioning
PKI/Certificates	AD CS (built-in)	Third-party CA integration, Entra CBA

SECTION 2 — AUTHENTICATION ARCHITECTURE

2.1 Authentication Concepts

2.1.1 Single Factor Authentication (SFA)

SFA relies on a single credential type — traditionally a password or PIN. Despite its simplicity, SFA is critically vulnerable: passwords are phishable, reused, brute-forced, and harvested at scale. Enterprise security standards have moved firmly away from SFA for any privileged or sensitive access scenario.

2.1.2 Multi-Factor Authentication (MFA)

MFA requires two or more independent authentication factors from different categories. The combination ensures that compromise of one factor does not grant access. MFA dramatically reduces account takeover risk: Microsoft reports that MFA blocks 99.9% of automated credential stuffing attacks.

2.1.3 Passwordless Authentication

Passwordless authentication eliminates the shared secret entirely. Users authenticate using possession (hardware key, passkey) or inherence (biometric) factors, bound cryptographically to the authenticating device. Authentication becomes phishing-resistant because there is no password to steal or replay. FIDO2/WebAuthn and Microsoft Entra ID's Passwordless Phone Sign-in are leading implementations.

2.1.4 Adaptive Authentication

Adaptive authentication dynamically adjusts the authentication requirement based on contextual risk signals evaluated at the time of the access request. If the risk score is low (known device, normal location, business hours), authentication may proceed with a single factor. If risk signals are elevated (new device, unusual location, impossible travel), step-up authentication is required. Adaptive authentication balances security with user experience.

2.1.5 Risk-Based Authentication (RBA)

Risk-Based Authentication is the evaluation engine that powers adaptive authentication. It continuously scores requests using signals such as: IP reputation, geolocation and velocity, device posture and registration status, time of access, behavioral baselines (typing cadence, navigation patterns), and threat intelligence feeds. The output is a dynamic risk score that drives access policy enforcement.

2.2 Authentication Factors

Factor Category	Description	Examples	Strengths	Weaknesses
Knowledge	Something the user knows	Password, PIN, security questions	Simple to implement	Phishable, guessable, reusable
Possession	Something the user has	TOTP app, hardware token, smart card, passkey	Requires physical device	Can be lost/stolen; TOTP is SIM-swappable
Inherence	Something the user is	Fingerprint, face recognition, iris scan	Non-transferable, convenient	Privacy concerns, spoofing risk, enrollment friction
Behavioral	How the user behaves	Typing patterns, mouse dynamics, gait analysis	Passive, continuous verification	Requires baseline training, can drift

2.3 Modern Authentication Technologies

2.3.1 FIDO2 and WebAuthn

FIDO2 (Fast Identity Online 2) is a set of open authentication standards developed by the FIDO Alliance. WebAuthn is the W3C web authentication API that enables browser-based applications to use FIDO2 authenticators. Together, they provide the foundation for phishing-resistant, passwordless authentication.

FIDO2 uses asymmetric cryptography: during registration, the authenticator generates a key pair — the public key is registered with the server, the private key never leaves the device. During authentication, the server sends a challenge signed by the private key and verified against the stored public key. Since credentials are bound to the origin (domain), phishing attacks that redirect to fake sites fail — the credential is simply not valid for the attacker's origin.

- Platform authenticators: Built into the device OS (Windows Hello, Apple Touch ID/Face ID, Android biometrics)
- Roaming authenticators: External devices (YubiKey, Titan Security Key, SoloKey)
- Supported by all major browsers and operating systems since 2019

[i] FIDO2/WebAuthn authentication is considered phishing-resistant and is the strongest form of MFA currently available for human users.

2.3.2 Passkeys

Passkeys are the consumer-friendly implementation of FIDO2 credentials, introduced through industry collaboration among Apple, Google, and Microsoft. Unlike traditional FIDO2 hardware keys, passkeys are synchronized across devices via the cloud (iCloud Keychain, Google Password Manager), making them both phishing-resistant and recoverable. Passkeys represent the most practical path to enterprise passwordless adoption.

2.3.3 Hardware Tokens (TOTP/HOTP)

Hardware tokens generate one-time passwords (OTPs) using TOTP (Time-based OTP, RFC 6238) or HOTP (HMAC-based OTP, RFC 4226). TOTP generates a new 6-8 digit code every 30 seconds using a shared secret. While more secure than SMS OTP (which is vulnerable to SIM swapping and SS7 attacks), TOTP is still susceptible to real-time phishing — attackers can relay the OTP in an automated adversary-in-the-middle (AiTM) attack. Hardware tokens remain appropriate for privileged access where FIDO2 is not yet deployed.

2.3.4 Smart Cards and Certificate-Based Authentication (CBA)

Smart cards store an X.509 certificate and the corresponding private key in a tamper-resistant hardware chip. Authentication is performed by signing a challenge with the private key, which is verified against the certificate issued by a trusted CA. Smart cards are widely used in government (PIV/CAC cards) and high-security enterprises. Microsoft Entra ID now supports certificate-based authentication (CBA) for cloud resources, providing smart card-level assurance in hybrid environments.

2.3.5 Biometrics

Biometric authentication uses physiological or behavioral characteristics for identity verification. Enterprise implementations include Windows Hello for Business (facial recognition, fingerprint on managed endpoints), Apple Touch ID/Face ID, and enterprise-grade fingerprint readers. Modern biometrics operate in a 'match-on-device' model — the biometric template never leaves the device, addressing privacy concerns and eliminating the risk of biometric database compromise.

2.4 Identity Protocols and Standards

2.4.1 SAML 2.0 (Security Assertion Markup Language)

Purpose

SAML 2.0 is an XML-based open standard for exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP). It is the dominant protocol for enterprise SSO with legacy web applications, cloud SaaS platforms, and B2B federation scenarios.

Architecture and Flow

SAML defines three actors: the Principal (user), the Identity Provider (authenticating authority), and the Service Provider (resource application). The standard SP-initiated flow: (1) User attempts to access SP. (2) SP generates an AuthnRequest and redirects user to IdP. (3) IdP authenticates user, generates a signed SAML Assertion (XML document containing the subject identity, attributes, and validity period), and returns it to the user's browser. (4) Browser submits the Assertion to the SP via HTTP POST. (5) SP validates the assertion signature against the IdP's certificate, extracts identity attributes, and creates a session.

Security Considerations

- SAML assertions must be signed (and ideally encrypted) to prevent forgery and eavesdropping
- Replay attacks are mitigated via assertion validity windows and InResponseTo tracking
- XML Signature Wrapping (XSW) attacks target implementations that validate the wrong element
- SAML Bearer Assertions require HTTPS to protect against token theft in transit

Real-World Use Case

An enterprise using Okta as its IdP federates access to Salesforce, ServiceNow, and Workday via SAML. Employees authenticate once with Okta MFA and receive seamless access to all integrated applications. Okta sends a SAML assertion to each SP containing the user's email, department, and role attributes used for application-level authorization.

2.4.2 OAuth 2.0

Purpose

OAuth 2.0 is an authorization framework (not an authentication protocol) that enables third-party applications to obtain limited access to resources on behalf of a resource owner without exposing the owner's credentials. It is the foundational protocol for API authorization, mobile app access, and delegated authorization.

Core Concepts

- Resource Owner: The entity (user) owning the resource to be accessed
- Client: The application requesting access on behalf of the resource owner
- Authorization Server: Issues access tokens after authenticating the resource owner and obtaining consent

- Resource Server: Hosts protected resources; validates access tokens to authorize requests
- Access Token: Short-lived credential issued by the authorization server, used to access resource APIs
- Refresh Token: Long-lived credential used to obtain new access tokens without re-authentication

Grant Types

Grant Type	Use Case	Security Notes
Authorization Code + PKCE	Web apps, SPAs, mobile apps	Most secure; PKCE prevents code interception attacks
Client Credentials	Machine-to-machine (M2M)	No user involved; client authenticates with secret or certificate
Device Code	Devices with limited input (TV, IoT)	User authenticates on secondary device
Implicit (deprecated)	Legacy SPAs	Deprecated in OAuth 2.1; tokens exposed in browser history
Resource Owner Password (deprecated)	Legacy first-party apps	Exposes credentials to client; avoid entirely

Security Considerations

- Always use PKCE (Proof Key for Code Exchange) for public clients
- Validate the redirect_uri strictly to prevent open redirect attacks
- Use short-lived access tokens (15-60 minutes) with refresh token rotation
- Never store access tokens in browser localStorage; use httpOnly cookies or memory

2.4.3 OpenID Connect (OIDC)

Purpose

OpenID Connect is an identity layer built on top of OAuth 2.0 that enables authentication. While OAuth 2.0 handles authorization ('what can you do'), OIDC handles authentication ('who are you'). OIDC adds the ID Token — a JWT containing claims about the authenticated user — and the UserInfo Endpoint for retrieving additional profile data. OIDC has become the dominant modern authentication protocol for cloud applications, mobile apps, and APIs.

Flow

The OIDC authorization code flow: (1) Client redirects user to IdP authorization endpoint with scope=openid. (2) IdP authenticates user. (3) IdP issues an authorization code. (4) Client exchanges code for ID Token and Access Token. (5) Client validates ID Token JWT signature and claims (iss, aud, exp, nonce). (6) Optionally calls UserInfo endpoint with Access Token for additional claims.

Security Considerations

- Validate all JWT claims: issuer (iss), audience (aud), expiration (exp), and nonce
- Use back-channel logout for secure session termination
- Require PKCE for all public clients
- Verify the ID Token signature against the IdP's JWKS endpoint

2.4.4 Kerberos

Purpose

Kerberos is a network authentication protocol that uses symmetric-key cryptography and a trusted third party (Key Distribution Center) to authenticate service requests over an untrusted network. It is the default authentication protocol for Windows Active Directory environments and is used extensively in enterprise on-premises and hybrid deployments.

Architecture

Kerberos uses three server components: the Authentication Server (AS), the Ticket Granting Server (TGS), and Service Servers (SS). The AS and TGS together constitute the Key Distribution Center (KDC). The Kerberos flow: (1) Client requests a Ticket Granting Ticket (TGT) from the AS using their password hash. (2) AS validates credentials, issues an encrypted TGT. (3) Client presents TGT to TGS to request a Service Ticket for a specific resource. (4) Client presents Service Ticket to the resource server for access.

Security Considerations

 *Kerberos is the primary target of advanced lateral movement attacks. Kerberoasting, Golden Ticket, Silver Ticket, and Pass-the-Ticket attacks all exploit weaknesses in Kerberos implementation.*

- Service Principal Names (SPNs) with weak encryption (RC4) are vulnerable to Kerberoasting offline cracking
- KRBTGT account compromise enables Golden Ticket attacks — forged TGTs with arbitrary lifetimes
- Enforce AES-256 encryption; disable legacy RC4/DES encryption in your environment
- Monitor for anomalous TGT requests, unusual service ticket patterns, and KRBTGT password age

2.4.5 SCIM (System for Cross-domain Identity Management)

Purpose

SCIM (RFC 7642-7644) is a REST-based protocol for automating user provisioning and de-provisioning between identity providers and applications. SCIM standardizes the API format for creating, reading, updating, and deleting (CRUD) identity resources, enabling HR-driven provisioning automation without custom integration code.

Architecture

SCIM defines a Service Provider (the application receiving provisioning requests) and a Client (the IdP or IGA platform sending them). The protocol uses standard REST operations over HTTPS with a JSON payload schema for Users and Groups. A SCIM PUT or POST from

Okta/Entra ID to a target application creates or modifies user accounts; a DELETE or deactivate operation triggers de-provisioning.

Real-World Use Case

When an employee joins, the HR system (Workday) triggers a SCIM push to Okta, which creates the user's identity profile. Okta then propagates the provisioning event via SCIM to Salesforce, GitHub, and Jira — creating accounts with appropriate group memberships and roles. When the employee leaves, the Workday termination event triggers Okta to SCIM-deactivate all downstream accounts within minutes.

2.4.6 WS-Federation

WS-Federation is a web services standard for federated identity that predates SAML 2.0 and is still used in legacy Microsoft environments (SharePoint, ADFS). It uses Security Token Service (STS) actors to exchange identity tokens. Most modern environments are migrating from WS-Federation to SAML 2.0 or OIDC, but WS-Federation remains relevant for ADFS integrations and some legacy enterprise applications.

SECTION 3 — AUTHORIZATION & ACCESS CONTROL

3.1 Access Control Models

Access control models define the rules and mechanisms that govern how subjects (users, services) interact with objects (files, APIs, databases, systems). Selecting the appropriate model — or combining models — is a critical architecture decision with direct security and operational implications.

3.1.1 Discretionary Access Control (DAC)

In DAC, the resource owner controls access and can grant or revoke permissions to other subjects at their discretion. Unix file permissions (owner/group/other read/write/execute) and Windows NTFS ACLs are classic DAC implementations. DAC is flexible but difficult to govern at scale — access decisions are distributed across resource owners, creating auditability and compliance challenges.

3.1.2 Mandatory Access Control (MAC)

MAC enforces access based on security labels assigned to subjects and objects by a central authority — not by resource owners. Subjects can only access objects with equal or lower sensitivity labels (Bell-LaPadula: no read up, no write down). MAC is used in government/military environments (SELinux, AppArmor, Trusted Solaris) where information flow must be strictly controlled. It is too rigid for most commercial enterprise applications.

3.1.3 Role-Based Access Control (RBAC)

RBAC assigns permissions to roles, and users are assigned to roles based on their job function. Access is controlled by role membership rather than individual user permissions. RBAC is the dominant model for enterprise applications, directory services (Active Directory groups), cloud IAM (AWS IAM roles, Azure RBAC), and Kubernetes.

- RBAC greatly simplifies access management — permission changes are made at the role level
- Effective RBAC requires disciplined role engineering and regular role recertification
- Role explosion (hundreds of fine-grained roles) is a common anti-pattern that negates RBAC benefits
- Separation of Duties (SoD) conflicts must be explicitly modeled and enforced

3.1.4 Attribute-Based Access Control (ABAC)

ABAC makes access decisions based on attributes of the subject (user), object (resource), action, and environment. Policies are expressed as logical conditions: IF user.department = 'Finance' AND resource.classification = 'Confidential' AND time BETWEEN 09:00-18:00 THEN PERMIT. ABAC enables highly granular, context-aware access control without requiring role proliferation. XACML is the standards-based policy language for ABAC.

Cloud IAM policies are largely ABAC in practice — AWS IAM condition keys, Azure Conditional Access, and GCP IAM conditions all implement ABAC concepts.

3.1.5 Policy-Based Access Control (PBAC)

PBAC is a superset of ABAC that expresses access rules as high-level policies combining role, attribute, and contextual logic. PBAC decouples policy from application code, enabling enterprise-wide policy administration through a central policy authority (e.g., OPA — Open Policy Agent, AWS Verified Permissions). PBAC is the emerging model for Zero Trust and cloud-native authorization architectures.

ACCESS CONTROL MODELS COMPARISON					
MODEL	 DAC DISCRETIONARY ACCESS CONTROL	 MAC MANDATORY ACCESS CONTROL	 RBAC ROLE-BASED ACCESS CONTROL	 ABAC ATTRIBUTE-BASED ACCESS CONTROL	 PBAC POLICY-BASED ACCESS CONTROL
 DESCRIPTION	Resource owner decides who gets access.	System enforces access based on classification levels and labels.	Access is granted based on roles assigned to users.	Access is granted based on attributes of user, resource, environment.	Access is determined using policies that evaluate multiple factors.
 ACCESS DECISION BASED ON	User/Resource Owner	Security Labels / Clearance Levels	Roles	Attributes (User, Resource, Action, Environment)	Policies (Rules + Conditions)
 FLEXIBILITY	 MODERATE	 LOW	 HIGH	 VERY HIGH	 VERY HIGH
 SECURITY STRENGTH	 MODERATE	 VERY HIGH	 HIGH	 VERY HIGH	 VERY HIGH
 COMPLEXITY	 LOW	 MODERATE	 MODERATE	 HIGH	 HIGH
 BEST USE CASE	 Small teams, file systems, collaborative environments	 Government, military, highly regulated organizations	 Enterprise applications, business systems	 Dynamic environments, cloud, zero trust scenarios	 Complex enterprises with advanced policy requirements

3.2 Principle of Least Privilege (PoLP)

The Principle of Least Privilege states that every entity — user, service, or system — should operate with the minimum set of permissions necessary to perform its function, for the minimum duration required. PoLP is foundational to limiting the blast radius of credential compromise, insider threats, and privilege escalation attacks.

3.2.1 Design Methodology

1. Start from zero: Default deny all access; grant only what is explicitly required
2. Define access requirements from job function, not from what was 'convenient before'
3. Separate development, staging, and production access — no shared credentials
4. Distinguish read from write from admin: most users need read, fewer need write, almost none need admin
5. Time-bound elevated access: Use JIT mechanisms; avoid standing privileged access
6. Review and recertify: Quarterly access certification to reclaim unused permissions

3.2.2 Enterprise Enforcement

- AWS: IAM policy analysis tools (IAM Access Analyzer, AWS Trusted Advisor) identify unused permissions
- Azure: Entra ID access reviews, PIM access requests, and conditional access policies
- Kubernetes: RBAC Roles with specific verbs/resources; no use of cluster-admin for non-infrastructure workloads
- PAM: JIT privilege elevation replaces standing admin accounts; all privileged access is time-bounded

3.3 Segregation of Duties (SoD)

Segregation of Duties is the principle that no single individual should have sufficient access to execute a complete high-risk business process without a second person's involvement. SoD is a cornerstone of financial controls and fraud prevention — it ensures that the person who initiates a transaction cannot also approve and settle it.

3.3.1 SoD Conflict Examples

Domain	Conflicting Roles/Permissions	Risk if Combined
Financial	Accounts Payable + Payment Authorization	Fraudulent payments without approval
IT	System Administration + Audit Log Management	Admin can cover tracks by deleting logs
Procurement	Purchase Requisition + Purchase Order Approval	Unauthorized spending
IAM	Identity Provisioning + Access Certification	Self-certified inappropriate access
Development	Code Commit + Production Deployment	Unauthorized code in production
Security	Firewall Rule Change + Firewall Rule Approval	Unauthorized network access

IGA platforms (SailPoint, Saviynt) maintain SoD rulebooks that automatically detect conflicts during provisioning and flag violations during access certification campaigns. SoD enforcement is a key SOX and PCI-DSS compliance requirement.

3.4 Just-In-Time (JIT) Access

Just-In-Time access is a PAM and IAM strategy in which privileged access is granted only when needed, for a specific task, for a defined duration, and is automatically revoked upon expiry or task completion. JIT eliminates standing privileged access — one of the most dangerous security posture weaknesses in enterprise environments.

3.4.1 JIT Implementation Patterns

- Approval-based elevation: User submits a request, approver reviews and approves, time-bounded access is granted (Azure PIM, CyberArk EPM)
- Self-service with justification: User provides business justification, access is granted automatically for short duration with full audit trail
- Workflow-integrated JIT: JIT access is triggered automatically by ITSM ticket (ServiceNow integration) — access is provisioned for the change window duration
- Just-in-time VM access (Azure): Network-level JIT port opening for RDP/SSH — port 3389/22 is closed by default, opened only for specific IPs for a defined window

3.5 Just Enough Administration (JEA)

Just Enough Administration is a PowerShell security feature in Windows/Azure that constrains what administrative actions a user can perform, even when granted a privileged role. JEA creates role capability files that whitelist specific cmdlets, parameters, and scripts that a given role may execute — operators get just the administrative tools they need for their function, nothing more.

A database administrator granted JEA access can restart the SQL Server service and check database health — but cannot access the file system, modify user accounts, or execute arbitrary PowerShell. JEA is a powerful PoLP enforcement mechanism for server administration that dramatically reduces the risk of malicious or accidental privilege abuse.

- JEA sessions are logged in detail (all commands, parameters, output) for audit purposes
- JEA constrained endpoints can be used as PAM-less privileged access control for specific admin tasks
- JEA is administered via PowerShell session configuration files (.pssc) and role capability files (.psrc)

SECTION 4 — PRIVILEGED ACCESS MANAGEMENT (PAM)

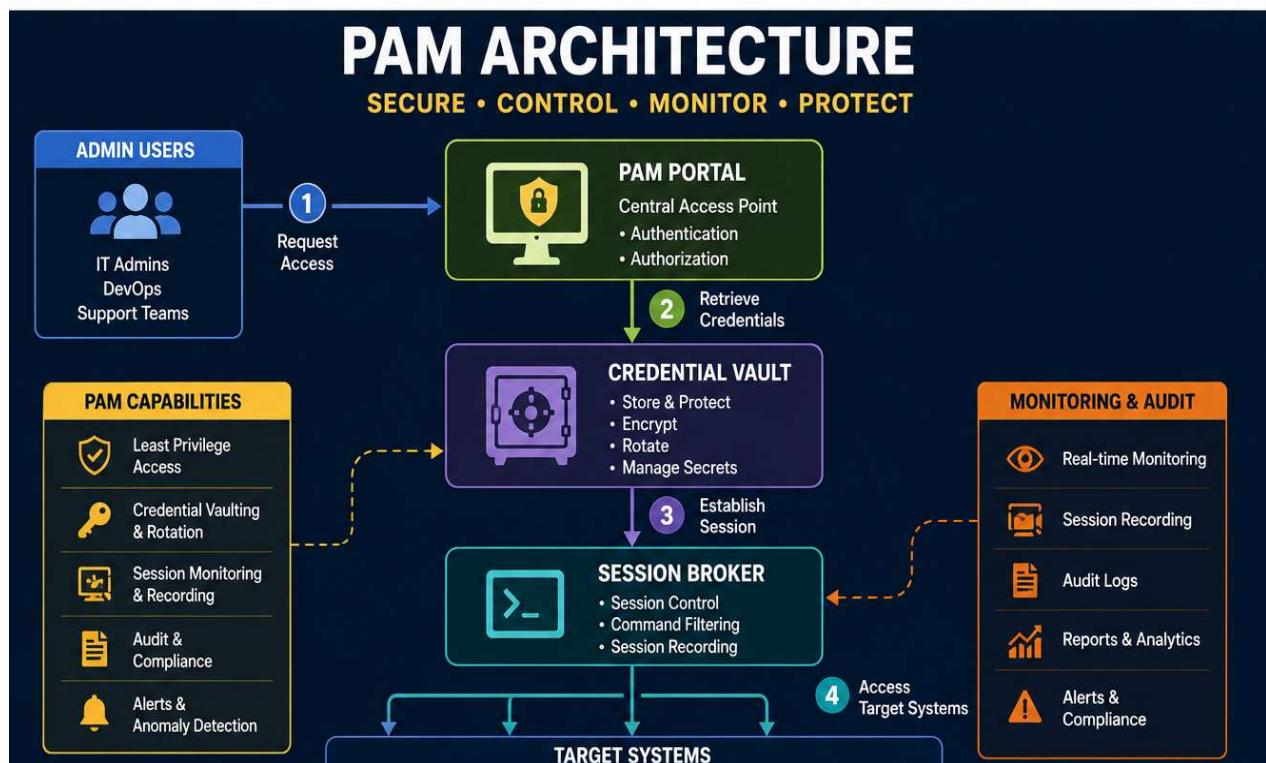
4.1 What Is Privileged Access Management

Privileged Access Management is the discipline of controlling, monitoring, and auditing access to high-value accounts, credentials, and systems that have elevated permissions beyond those of standard users. Privileged accounts represent the highest-risk identities in any enterprise environment — their compromise can provide an attacker with complete control over infrastructure, data, and security controls.

The Cybersecurity and Infrastructure Security Agency (CISA), NIST, and virtually every enterprise security framework identify PAM as a top control priority. Gartner consistently ranks PAM among the highest-ROI security investments for enterprises, primarily because it directly addresses the lateral movement and privilege escalation paths used in the most damaging breaches.

4.1.1 The Privileged Threat Landscape

- In 2023 attacks, 74% of breaches involved the abuse of privileged accounts (Verizon DBIR)
- Default admin credentials on servers, network devices, and cloud consoles remain one of the most exploited attack vectors
- Lateral movement via pass-the-hash and Kerberoasting relies on extracting and reusing privileged credential material
- Cloud privilege escalation via misconfigured IAM roles is the primary attack path in cloud breaches



4.2 Privileged Account Types

Account Type	Description	Typical Location	Risk Profile
Local Admin	Local administrator on workstations/servers	Windows/Linux endpoints	Pass-the-hash, credential reuse
Domain Admin	Full AD domain administrative rights	Active Directory	Complete AD compromise, Golden Ticket
Root Account	Superuser on Linux/Unix systems	Linux servers, containers	Unrestricted system access
Service Account	Accounts used by applications/services	AD, local systems, databases	Often over-privileged, stale passwords
Break-Glass Account	Emergency access for disaster scenarios	Vaulted, offline or PIM	Unmonitored use, credential exposure
Shared Admin	Shared credentials among admin teams	Network devices, legacy systems	No accountability, no rotation
Cloud Privileged	AWS root, Azure Global Admin, GCP Project Owner	Cloud consoles	Full cloud environment compromise
API Privileged	API keys with admin-level permissions	CI/CD, automation scripts	Hardcoded secrets, long-lived tokens
Database Admin	DBA accounts with full data access	SQL Server, Oracle, MongoDB	Data exfiltration, schema modification
SSH Keys	Root/admin SSH keypairs	Linux infrastructure	Key sprawl, no rotation, no audit trail

4.3 PAM Core Capabilities

4.3.1 Credential Vaulting

Credential vaulting is the secure storage of privileged credentials (passwords, SSH keys, API keys, certificates) in an encrypted, access-controlled vault. The vault becomes the single authoritative store for privileged credentials — application teams and administrators never directly possess credentials. Access is brokered: users authenticate to the vault, receive time-limited access to the resource, and the credential itself may never be revealed to the user (transparent proxy mode).

- Credentials are encrypted at rest using HSM-backed keys (FIPS 140-2 Level 2/3)
- The vault provides full audit trail of every credential access and usage event
- Vault high availability and disaster recovery are critical infrastructure requirements
- Vault API enables programmatic access for DevOps and automation use cases

4.3.2 Automated Password Rotation

PAM systems automatically rotate privileged credentials on a defined schedule (daily, after each use, or upon session termination). Rotation eliminates the ability to use a previously harvested credential — even if an attacker obtained the password, it will be changed before they can use it. Rotation is performed via platform-specific connectors (Windows, Linux, database, network device) that update the credential both in the vault and on the target system atomically.

 *A critical operational dependency: applications and scripts that hard-code credentials will break upon rotation. Application credential migration to vault API calls is a prerequisite for rotation enablement.*

4.3.3 Session Management

PAM session management brokers privileged sessions between the user and the target system. The user connects to the PAM gateway, authenticates, and the gateway initiates the privileged session to the target on their behalf. The user may never see the actual credential. Session management enables full proxy-mode PAM where credentials are completely abstracted.

- Protocol support: RDP, SSH, HTTPS, database (SQL), mainframe, and cloud console sessions
- Session launch via approved workflow or JIT request
- Session timeout and auto-termination upon inactivity or time limit expiry
- Multi-user session sharing for collaborative troubleshooting (with dual control)

4.3.4 Session Monitoring and Recording

PAM platforms record all privileged sessions — capturing full video recording of GUI sessions (RDP) and keystroke/command logging for terminal sessions (SSH). Session recordings are stored in a tamper-evident store and can be reviewed for audit, forensic investigation, and compliance evidence purposes. Real-time session monitoring enables security teams to watch active privileged sessions and terminate suspicious activity.

- OCR capabilities enable searching session recordings for specific commands or actions

- Session recordings are admissible evidence in security incidents and legal proceedings
- User Behavior Analytics (UBA) can analyze session command sequences for anomaly detection
- SIEM integration alerts on high-risk commands executed during privileged sessions

4.3.5 Secrets Management

Secrets management extends PAM capability to DevOps and machine identity contexts — managing API keys, OAuth tokens, database credentials, TLS certificates, and encryption keys used by applications, CI/CD pipelines, and automated systems. Unlike human-centric vaulting, secrets management focuses on programmatic access: applications authenticate to the secrets manager and retrieve credentials dynamically at runtime, eliminating hard-coded secrets.

- HashiCorp Vault: Most widely deployed enterprise secrets manager; dynamic secrets, PKI, encryption-as-a-service
- AWS Secrets Manager: Native cloud secrets manager with automatic rotation for RDS, Redshift, and custom secrets
- Azure Key Vault: Managed secrets, keys, and certificates with Azure AD integration and HSM backing
- CyberArk Conjur: Enterprise-grade secrets manager integrated with the CyberArk PAM ecosystem

4.3.6 Just-In-Time Privilege Elevation

PAM-integrated JIT ensures that privileged access is granted on-demand, for a specific purpose, for the minimum duration. The workflow: (1) User or automated process requests elevated access via PAM portal or API. (2) Request is evaluated against policy (who can approve, what access level, for how long). (3) Approver(s) review and approve via ITSM integration or PAM console. (4) Privileged access is provisioned and the session begins. (5) At session end or time expiry, privilege is automatically revoked and password rotated.

4.3.7 Approval Workflows and Dual Control

For the most sensitive operations (production database access, firewall rule changes, break-glass account activation), PAM platforms enforce dual control — a second authorized person must approve before access is granted. This mirrors the SoD principle and provides a critical check against insider threats, social engineering, and coercion. Approvals can be integrated with ITSM platforms (ServiceNow, Jira) to link privileged access to authorized change tickets.

4.4 PAM Architecture Patterns

4.4.1 Vault-Based PAM

The traditional PAM architecture centers on a central vault that stores all privileged credentials. Users authenticate to the vault, retrieve credentials (or launch brokered sessions), and all access is logged. The vault is the authoritative system for credential storage, rotation, and access control. CyberArk Enterprise Password Vault is the canonical implementation.

4.4.2 Proxy-Based PAM

Proxy-based PAM inserts a gateway between the user and the target system. The user never connects directly to the target — all traffic flows through the PAM proxy, which handles authentication, session recording, and policy enforcement. The credential itself may never be transmitted to the user in proxy mode. This architecture is ideal for environments where credential exposure must be completely eliminated.

4.4.3 Agent-Based PAM

Agent-based PAM deploys a lightweight software agent on target systems to enforce local privilege policies, capture local activity, and integrate with the central PAM platform. The agent enforces application whitelisting, privilege elevation rules (run-as-admin for specific approved applications), and keystroke logging at the endpoint. BeyondTrust Endpoint Privilege Management (EPM) and CyberArk Endpoint Privilege Manager are agent-based implementations.

4.4.4 Hybrid PAM

Enterprise PAM deployments typically combine all three patterns: vault-based credential storage, proxy-based session brokering for remote infrastructure access, and agent-based endpoint privilege management for workstations and servers. Cloud PAM capabilities (Azure PIM, AWS IAM Identity Center) complement on-premises PAM platforms for cloud resource access governance.

4.5 Modern PAM Platforms

Platform	Primary Strengths	Cloud Support	Best For
CyberArk	Deepest vault/session capabilities, large enterprise ecosystem, EPM agent	AWS, Azure, GCP modules; CyberArk Cloud Entitlements Manager	Large enterprises with complex on-prem and cloud hybrid environments
BeyondTrust	Strong endpoint privilege mgmt, remote support integration, AD bridging	Cloud PAM, AWS/Azure integration	Enterprises prioritizing endpoint privilege reduction
Delinea (Thycotic/Centrify)	Flexible deployment, strong server privilege, AD bridging for Linux	Cloud Suite for cloud-native environments	Mid-market to enterprise with mixed OS environments
HashiCorp Vault	Developer-friendly secrets management, dynamic secrets, PKI, encryption	Cloud-agnostic; runs anywhere	DevSecOps, cloud-native, Kubernetes workloads
Microsoft Entra PIM	Native Azure/M365 integration, no additional agent, conditional access integration	Azure native, M365	Microsoft-centric enterprises with Azure RBAC
AWS IAM Identity Center	Native AWS SSO and permission sets, multi-account governance	AWS native	AWS-native organizations with multi-account structure
Okta PAM	Unified IAM/PAM platform, infrastructure access with full Okta integration	Cloud-first	Organizations using Okta as primary IdP seeking unified platform

SECTION 5 — IDENTITY GOVERNANCE & ADMINISTRATION (IGA)

5.1 What Is Identity Governance

Identity Governance and Administration (IGA) is the framework of policies, processes, and technologies that ensure identities have appropriate access rights throughout their lifecycle — and that access can be proven compliant to auditors, regulators, and business owners. IGA provides the governance layer that sits above IAM operational capabilities, enforcing business policy over access entitlements.

IGA addresses the fundamental governance question: 'Does this person actually need this access for their job?' — answered at scale across thousands of identities and applications. Without IGA, enterprises accumulate years of access drift where permissions granted for temporary projects, role changes, or business convenience are never revoked.

5.2 The Joiner-Mover-Leaver (JML) Process

5.2.1 Joiner (New Hire / Onboarding)

When a new employee joins, the HR system (Workday, SAP HCM, Oracle HCM) creates the identity record and triggers the provisioning workflow. IGA platforms receive this event via SCIM or API and execute automated provisioning rules based on the employee's attributes — department, job title, location, manager, and business unit. Access is provisioned following role-based templates that represent the minimum required access for that job function.

- Automated account creation: AD/Entra ID, email, collaboration tools (Teams, Slack)
- Role-based access assignment: Application access based on job function templates
- Manager notification and approval for any access not covered by standard templates
- SLA enforcement: Provisioning completed within defined timeframes (e.g., 4 hours for business-critical access)

5.2.2 Mover (Role Change / Transfer)

When an employee changes roles, transfers departments, or is promoted, their access must be updated to reflect their new responsibilities — and legacy access from their previous role must be revoked. This is the most commonly neglected lifecycle event and the primary driver of permission creep. IGA platforms receive mover events from HR and trigger both provisioning of new access and de-provisioning of no-longer-required access.

 *Permission creep — the accumulation of access rights across multiple role changes — is one of the most dangerous IAM posture weaknesses. An employee who has held five roles over ten years may have access appropriate to all five roles simultaneously.*

5.2.3 Leaver (Termination / De-provisioning)

When an employee leaves — whether voluntarily, involuntarily, or through contractor expiry — all access must be revoked promptly and completely. IGA platforms execute full de-provisioning across all managed systems upon receipt of the termination event. Speed is critical: the window between termination and access revocation is a significant insider threat risk.

- Immediate disablement of primary authentication accounts (AD, Entra ID, Okta)
- Revocation of all SSO-federated application access
- De-provisioning of database accounts, VPN access, cloud console access
- Revocation of API keys, SSH keys, and service account access associated with the individual
- Email forwarding configuration and mailbox transfer per legal/HR requirements

[i] Target: Full de-provisioning within 4 hours of termination event for standard employees; immediate (same-day, manual) for high-risk terminations.

5.3 Access Certification Campaigns

Access certification (also called access reviews or recertification) is the periodic review of existing access entitlements by accountable business managers and data owners to confirm that access is still appropriate and needed. Certification campaigns are a cornerstone of compliance frameworks (SOX, SOC 2, ISO 27001) and the primary mechanism for detecting and remediating access drift.

5.3.1 Certification Campaign Types

- User Access Review: All access for a specific user — typically triggered by role change or annual review
- Entitlement Review: All users with a specific entitlement — identifying if access is appropriately distributed
- Role Review: All permissions within a role — validating that the role definition is current and appropriate
- Application Access Review: All users with access to a specific application — often required by application owners
- Privileged Account Review: All privileged accounts — high frequency (quarterly), focused on active privileged access

5.3.2 Certification Workflow

IGA platforms (SailPoint, Saviynt) orchestrate certification workflows: (1) Define the campaign scope, reviewers, and deadline. (2) Generate access snapshots from all connected systems. (3) Present reviewers with their decisions (certify/revoke) via web interface. (4) Track completion, send escalation reminders, and enforce deadline actions. (5) Automatically execute revocation for any 'deny' or non-responded decisions. (6) Generate audit evidence report for compliance consumption.

5.4 Role Engineering

Role engineering is the process of designing, rationalizing, and maintaining the role model that drives RBAC and IGA policies. Poor role design — too many roles, overlapping roles, roles that accumulate over time without rationalization — undermines the governance value of IGA. Effective role engineering ensures roles map to business job functions, have clear ownership, and are governed through a role lifecycle process.

- Business Role: Maps to a job function (e.g., 'Financial Analyst', 'Site Reliability Engineer')
- IT Role: Maps to a set of IT system permissions required by the business role
- Entitlement: The lowest-level access right in a specific system (e.g., read permission in Salesforce)
- Role Mining: Analytical process of deriving role definitions from existing access patterns using data analytics

5.5 IGA Platforms

5.5.1 SailPoint IdentityNow / IdentityIQ

SailPoint is the market-leading IGA platform, available as a cloud SaaS (IdentityNow) or on-premises (IdentityIQ) deployment. SailPoint provides comprehensive identity governance including lifecycle management, access certification, role management, SoD enforcement, analytics, and AI-driven access recommendations. SailPoint integrates with over 200 applications via pre-built connectors and supports SCIM, REST, and custom connector development.

5.5.2 Saviynt Enterprise Identity Cloud

Saviynt is a cloud-native IGA platform with strong capabilities in cloud access governance, application GRC, and converged IGA/PAM (combining identity governance with privileged access management). Saviynt's cloud security manager provides visibility into cloud entitlements across AWS, Azure, and GCP, making it particularly strong for cloud-heavy enterprises.

5.5.3 Microsoft IGA Ecosystem

Microsoft's IGA capabilities are distributed across the Entra ID platform: Entra ID Governance (access reviews, entitlement management, lifecycle workflows), Identity Governance access packages, Entra PIM (privileged role governance), and integration with Microsoft 365 Compliance. For Microsoft-centric enterprises, Entra ID Governance provides native IGA capabilities without a separate IGA platform, though depth and connector breadth are narrower than SailPoint or Saviynt.

SECTION 6 — CLOUD IAM (MODERN CLOUD-FIRST SECURITY)

6.1 AWS Identity and Access Management

AWS IAM is the foundational access control service for AWS resources. Every API call in AWS is authorized through IAM — there is no out-of-band access path. Understanding AWS IAM is essential for any cloud security practitioner.

6.1.1 AWS IAM Core Components

Users

IAM Users represent long-term credentials associated with a specific individual or service. Best practice: avoid IAM users for human access — use IAM Identity Center (SSO) with federated identity instead. IAM users for programmatic access (CLI/API) should use access keys that are rotated regularly, or ideally, be replaced with IAM roles and short-term credentials.

Groups

IAM Groups are collections of IAM users for policy attachment convenience. Permissions attached to a group apply to all member users. Groups cannot be nested and cannot be used in IAM policy Principal elements.

Roles

IAM Roles are the preferred mechanism for granting permissions in AWS. Roles are assumed by identities (users, services, other accounts) and issue temporary security credentials (STS tokens). Roles eliminate long-lived access keys and enable cross-account access, EC2 instance profiles, Lambda execution roles, and federated access.

Policies

IAM Policies are JSON documents that define permissions. Policy types include: Identity-based policies (attached to users/roles/groups), Resource-based policies (attached to resources like S3 buckets, KMS keys), Permission boundaries (maximum permissions ceiling), Session policies (temporary permission reduction), and Service Control Policies (SCPs, applied at AWS Organization level).

Trust Relationships and SCPs

Trust relationships define who can assume a role (the Principal). SCPs in AWS Organizations provide preventive guardrails — they constrain the maximum permissions available to accounts within an OU, regardless of IAM policies. SCPs do not grant permissions; they restrict them. A common pattern is using SCPs to prevent deletion of CloudTrail logs, prevent disabling GuardDuty, or restrict regions for data residency compliance.

Permission Boundaries

Permission boundaries are a powerful IAM feature that defines the maximum permissions an identity-based policy can grant. Even if a role has a broad policy attached, a permission boundary limits effective permissions to the intersection. Permission boundaries are used to

delegate IAM role creation to development teams while preventing privilege escalation — the team can create roles, but only with permissions within the boundary they've been delegated.

6.1.2 AWS IAM Best Practices

- Enable MFA on the AWS root account immediately; do not use root for daily operations
- Use AWS IAM Identity Center (SSO) for human access with federated enterprise identity
- Use IAM Roles with instance profiles for EC2, Lambda, and container workloads (no access keys on compute)
- Apply Service Control Policies at the AWS Organizations level for preventive guardrails
- Enable AWS CloudTrail in all regions; send to a centralized, locked logging account
- Use IAM Access Analyzer to identify external access and unused permissions
- Enforce permission boundaries for delegated administrator patterns

6.2 Azure IAM / Microsoft Entra ID

6.2.1 Azure RBAC

Azure Role-Based Access Control governs access to Azure resources (subscriptions, resource groups, and specific resources). Azure RBAC uses role assignments that combine a security principal (user, group, service principal, managed identity), a role definition (set of allowed actions and notActions), and a scope (subscription, resource group, or resource). Built-in roles include Owner, Contributor, Reader, and hundreds of service-specific roles. Custom roles can be defined for granular permission sets.

6.2.2 Conditional Access

Entra ID Conditional Access is Microsoft's policy engine for Zero Trust access control. Policies are expressed as 'If-Then' conditions: IF user is in group X AND device is non-compliant AND location is outside corporate network THEN require MFA and block. Conditional Access evaluates signals including user identity, group membership, sign-in risk (Identity Protection), device compliance (Intune), application being accessed, IP location, and authentication strength (MFA, FIDO2).

- Named locations: Define trusted IP ranges and countries
- Authentication strength: Require FIDO2 or certificate-based auth for privileged roles
- Token protection (Preview): Bind tokens to device to prevent token theft
- Require compliant device: Block access from non-Intune-enrolled or non-compliant devices

6.2.3 Privileged Identity Management (PIM)

Azure PIM implements JIT privilege elevation for Azure AD roles (e.g., Global Administrator, Security Administrator) and Azure RBAC roles. Eligible users can activate a role for a defined period (typically 1-8 hours) with justification and optionally approval. All activations are logged and alertable. PIM Access Reviews require role owners to recertify eligible and active assignments on a defined schedule.

6.2.4 Managed Identities

Azure Managed Identities provide an automatically managed identity for Azure services (VMs, App Service, AKS, Functions). The identity is managed by Azure — no credentials to store, rotate, or manage. Applications authenticate to Azure services (Key Vault, Storage, SQL) using the managed identity token. System-assigned managed identities are tied to the resource lifecycle; user-assigned managed identities are independent and can be shared across resources.

6.3 Google Cloud IAM

6.3.1 GCP IAM Core Model

GCP IAM is built around three concepts: Principals (who), Roles (what), and Policies (binding). Principals include Google Accounts, service accounts, Google groups, Cloud Identity domains, and special identifiers (allUsers, allAuthenticatedUsers). Roles are collections of permissions; GCP provides Basic roles (Owner, Editor, Viewer — avoid these), Predefined roles (service-specific, least-privilege), and Custom roles. IAM policies bind principals to roles on specific resources.

6.3.2 GCP Service Accounts and Workload Identity

GCP Service Accounts are the primary identity mechanism for workloads running in GCP. Service accounts authenticate using short-lived OIDC tokens or service account keys (discouraged — keys are long-lived and must be managed). Workload Identity Federation allows workloads running outside GCP (e.g., GitHub Actions, AWS, on-premises) to authenticate to GCP services using their external identity, eliminating service account keys entirely.

6.4 Kubernetes IAM

6.4.1 Kubernetes RBAC

Kubernetes RBAC controls access to the Kubernetes API. Subjects (users, service accounts, groups) are granted permissions via Roles (namespace-scoped) or ClusterRoles (cluster-scoped), bound to subjects through RoleBindings and ClusterRoleBindings. Kubernetes does not manage user identities directly — human users authenticate via certificates, OIDC tokens (from Entra ID, Okta), or static tokens. Service accounts are the identity mechanism for pods.

- ClusterRoleBinding: cluster-admin is the most dangerous Kubernetes binding — restrict strictly
- ServiceAccount tokens are automatically mounted in pods by default; disable this for pods that don't need API access
- Use short-lived, projected service account tokens (TokenRequestAPI) rather than static service account secrets
- Admission controllers (OPA/Gatekeeper, Kyverno) enforce security policies on Kubernetes resources

6.4.2 Kubernetes Secrets

Kubernetes Secrets store sensitive data (passwords, tokens, certificates) in the cluster. By default, secrets are base64-encoded in etcd — not encrypted. Production-grade Kubernetes security requires: etcd encryption at rest, secrets stored in an external secrets manager (HashiCorp Vault, AWS Secrets Manager) with the External Secrets Operator or CSI Secrets Store driver, and RBAC limiting who can read secrets in each namespace.

6.5 Multi-Cloud IAM Strategy

Enterprises operating across AWS, Azure, and GCP face the challenge of managing disparate IAM models, policy languages, and governance frameworks. A coherent multi-cloud IAM strategy requires a central identity authority, consistent policy standards, and cross-cloud visibility.

Challenge	Strategy	Technology Examples
Identity sprawl	Federate all clouds to a single enterprise IdP	Okta, Entra ID as IdP for AWS, Azure, GCP
Policy inconsistency	Define cloud-agnostic policy standards; implement in each cloud	Terraform for IAM as code; CSPM tools for drift detection
Privileged access governance	Centralize PAM with cloud modules or native cloud PIM	CyberArk Cloud Entitlements Manager, Azure PIM, AWS Identity Center
Access visibility	CSPM and CIEM tools for entitlement visibility across clouds	Prisma Cloud, Wiz, Microsoft Defender for Cloud
Workload identity	Use Workload Identity Federation; eliminate cross-cloud static credentials	GCP WIF, AWS OIDC federation, Azure Managed Identities
Compliance reporting	Centralized SIEM and audit log aggregation	Splunk, Microsoft Sentinel, AWS Security Hub

SECTION 7 — DEVSECOPS & MACHINE IDENTITY

7.1 Secrets Management in DevSecOps

The DevSecOps pipeline is one of the highest-risk environments for credential exposure. CI/CD pipelines, infrastructure-as-code templates, container images, and application configurations routinely contain hard-coded credentials, API keys, and service account tokens. Effective secrets management in DevSecOps eliminates static, long-lived secrets from pipelines and code.

7.1.1 Secrets Anti-Patterns (What Not to Do)

⚠ Hard-coded secrets in source code are one of the most common and dangerous security failures. Secrets committed to Git repositories are frequently discovered by attackers via public repository scanning (GitHub secret scanning, GitLeaks, TruffleHog).

- Hard-coded passwords in application code (string literals, config files)
- Secrets stored in unencrypted .env files committed to version control
- Long-lived IAM access keys with broad permissions stored in CI/CD environment variables
- Shared service account credentials used by multiple pipelines without rotation
- Database passwords in Docker Compose files or Kubernetes manifest YAML

7.1.2 Secrets Management Best Practices

- Use dynamic secrets: HashiCorp Vault generates short-lived database credentials on demand; they expire automatically
- Use Workload Identity Federation: GitHub Actions, GitLab CI, and CircleCI can authenticate to cloud providers using OIDC tokens — no stored secrets
- Scan all code commits for secrets: Pre-commit hooks (detect-secrets, GitLeaks), CI-stage scanning, and repository-wide scanning
- Use CSI Secrets Store or External Secrets Operator for Kubernetes: Mount secrets from Vault/AWS Secrets Manager directly into pods
- Rotate all secrets on any potential exposure — treat secret exposure as a security incident

7.2 CI/CD Identity and Pipeline Security

CI/CD pipelines have become a primary attack target. The SolarWinds supply chain attack demonstrated how a compromised build pipeline can deliver malicious code to thousands of downstream targets. Pipeline identity must be treated with the same rigor as privileged human identities.

- Each pipeline should have a dedicated, least-privilege service identity
- OIDC federation between CI/CD platforms and cloud providers eliminates stored cloud credentials
- Pipeline execution context (branch, repo, organization) should be validated in the OIDC trust policy

- Secrets in pipeline variables should use masked, protected variables with audit logging
- Artifact signing (Sigstore, in-toto) provides supply chain integrity verification

7.3 Workload Identity Federation (WIF)

Workload Identity Federation is the modern approach to machine authentication that eliminates long-lived static credentials (API keys, service account keys) by replacing them with short-lived, cryptographically bound OIDC tokens. The workload presents its OIDC token to the cloud provider's STS (Security Token Service), which exchanges it for a short-lived cloud credential based on a predefined trust policy.

Workload Platform	Identity Token Type	Target Cloud	Implementation
GitHub Actions	GitHub OIDC token	AWS, Azure, GCP	Add OIDC provider in cloud; create trust policy binding repo/branch
GitLab CI	GitLab OIDC token	AWS, Azure, GCP	Configure OIDC provider; use id_tokens in pipeline YAML
Kubernetes Pod	ServiceAccount token (projected)	AWS, Azure, GCP	IAM Roles for Service Accounts (IRSA), Pod Workload Identity, WIF binding
Terraform Cloud	TFC OIDC token	AWS, Azure, GCP	Dynamic provider credentials; no stored cloud keys
On-premises workloads	SPIFFE SVID	Any	SPIRE + WIF or OIDC federation from on-premises IdP

7.4 SPIFFE and SPIRE

SPIFFE (Secure Production Identity Framework For Everyone) is an open-source standard for workload identity that assigns cryptographically verifiable identities to workloads regardless of where they run (cloud, on-premises, Kubernetes, VMs). A SPIFFE Verifiable Identity Document (SVID) is an X.509 certificate or JWT token that asserts the identity of a workload.

SPIRE (SPIFFE Runtime Environment) is the reference implementation of SPIFFE. SPIRE runs a server (central certificate authority) and agents (on each node) to attest workload identity using node attestors (TPM, cloud metadata, k8s service account) and workload attestors (process, container). SPIRE-issued SVIDs enable mTLS between services without static service account credentials.

7.5 Certificate Lifecycle Management

Machine identity at scale requires automated certificate lifecycle management. Manual certificate management is error-prone — certificate expiry is consistently among the top causes of service outages. Modern certificate management requires automation at every stage: issuance, renewal, revocation, and visibility.

- ACME protocol (Let's Encrypt, cert-manager for Kubernetes): Automated certificate issuance and renewal
- HashiCorp Vault PKI secrets engine: Internal CA for issuing short-lived certificates at scale
- Certificate transparency logs: Public monitoring for unauthorized certificate issuance
- CIEM and certificate inventory tools: Visibility into all certificates across the enterprise, with expiry alerting
- Short-lived certificates (24-hour to 7-day validity): Reduce the window for compromised certificate abuse

SECTION 8 — ZERO TRUST & MODERN SECURITY ARCHITECTURE

8.1 Zero Trust Principles

Zero Trust is a security model based on the principle that no entity — inside or outside the network perimeter — should be trusted by default. Every access request must be verified, every session authorized, and every connection treated as potentially hostile. The 2020 NIST Special Publication 800-207 formalized the Zero Trust Architecture (ZTA) framework.

8.1.1 Core Zero Trust Tenets (NIST SP 800-207)

7. All data sources and computing services are considered resources — location is not a trust signal
8. All communication is secured regardless of network location — no implicit trust for internal traffic
9. Access to individual enterprise resources is granted on a per-session basis — no standing access
10. Access to resources is determined by dynamic policy including identity, device, and behavior
11. The enterprise monitors and measures the integrity and security posture of all assets
12. All authentication and authorization is dynamic and strictly enforced before access is allowed
13. The enterprise collects information about the current state of assets and uses it to improve security posture

8.2 Identity's Role in Zero Trust

Identity is the foundational control plane in a Zero Trust architecture. Every access decision begins with identity: who is requesting, from what device, from where, at what time, accessing what resource. The identity infrastructure — IdP, MFA, device management, risk evaluation — must be robust, continuously monitored, and the authoritative source of truth for all access policy decisions.

8.2.1 Continuous Authentication and Verification

Zero Trust replaces the 'authenticate once, trust forever' session model with continuous authentication and contextual re-evaluation. After initial authentication, the system continuously evaluates risk signals throughout the session. Significant changes in risk — location change, device compliance failure, anomalous behavior — trigger step-up authentication or session termination without user intervention.

8.2.2 Conditional Access as Zero Trust Enforcement

Entra ID Conditional Access is the most widely deployed implementation of Zero Trust access policy. Each access request is evaluated against a set of conditions and enforcement actions. A Zero Trust Conditional Access baseline includes: block legacy authentication protocols (which bypass MFA), require MFA for all users, require compliant device for cloud application

access, block high-risk sign-ins (Identity Protection), and apply authentication strength requirements for privileged roles.

8.2.3 Device Trust

Zero Trust requires that devices be verified as compliant before being granted access to enterprise resources. Device trust is established through MDM enrollment (Intune, Jamf), compliance policy evaluation (OS version, encryption status, AV status, patch level), and device health attestation (TPM-backed). Non-compliant devices receive reduced or no access, regardless of user identity.

8.2.4 Context-Aware Access (BeyondCorp Model)

Google's BeyondCorp model, the practical precursor to Zero Trust, eliminates VPN in favor of context-aware application access. Access decisions are made at the application layer based on user identity, device certificate, device compliance, and user group membership. The Access Proxy validates context and enforces policy without requiring the user to be on a corporate network. Google Cloud's Identity-Aware Proxy (IAP) implements this model for GCP resources.

Zero Trust Dimension	Traditional Model	Zero Trust Model
Trust boundary	Corporate network perimeter	Every request individually evaluated
Authentication	Once per session at network entry	Continuous; step-up on risk change
Device trust	Implied by network location	MDM-enrolled, compliance verified
Access scope	Broad network access post-VPN	Least-privilege, per-application
Privileged access	Standing admin accounts	JIT elevation, time-bounded, approved
Lateral movement	Possible within trusted network	Prevented by micro-segmentation and context-aware access
Monitoring	Perimeter logging	Full session, API, and data plane logging with UEBA

SECTION 9 — IAM/PAM ATTACKS & DEFENSIVE SECURITY

9.1 Credential Theft

Attack Mechanics

Credential theft encompasses techniques to harvest valid user credentials — phishing, keyloggers, credential database dumps, browser password extraction, and LSASS memory dumping (Mimikatz). Once credentials are obtained, attackers use them for initial access or lateral movement.

Detection

- Anomalous login times, locations, or IP addresses vs. user baseline
- Failed authentication spikes followed by successful login (spraying pattern)
- LSASS access attempts (Sysmon Event 10 on LSASS process)

Mitigation

- MFA (blocks credential-only attacks), Credential Guard (protects LSASS), FIDO2 (eliminates phishable credentials), EDR protection

9.2 Password Spraying

Attack Mechanics

Password spraying tests a small set of commonly used passwords against a large number of accounts to avoid account lockout. Attackers target: 'Password123', 'Welcome1', 'CompanyName2024!'. Spraying is effective because lockout policies protect individual accounts, not aggregate failure rates across many accounts.

Detection

- Distributed failed authentications across many accounts within a time window (Entra ID Sign-in logs, Splunk SPL)
- Entra ID Identity Protection: 'Password spray' risk detection (automated)

Mitigation

- Entra ID Smart Lockout, Entra ID Identity Protection, MFA, banned password lists, Azure AD password protection

9.3 Kerberoasting

Attack Mechanics

Kerberoasting exploits the Kerberos service ticket mechanism. Any authenticated domain user can request a Service Ticket for any SPN-registered service account. The ticket is encrypted with the service account's password hash. Attackers extract the ticket offline and crack the password hash using tools like Hashcat. Service accounts with weak passwords and RC4 encryption are the primary targets.

Detection

- Unusual volume of TGS requests (Event ID 4769) for service accounts — especially RC4 encrypted (etype 0x17/0x18)
- TGS requests from accounts that don't normally request these services

Mitigation

- Use long, complex service account passwords (25+ characters) or Group Managed Service Accounts (gMSA) with 256-character auto-rotating passwords
- Enforce AES-256 Kerberos encryption; disable RC4 on service accounts
- Audit and minimize service accounts with SPNs; use gMSAs wherever possible

9.4 Golden Ticket Attack

Attack Mechanics

A Golden Ticket is a forged Kerberos TGT created using the KRBTGT account's NTLM hash. The KRBTGT account is the master key for all Kerberos tickets in a domain. With the KRBTGT hash, an attacker (using Mimikatz) can generate valid TGTs for any user, any group membership, with any expiration time — effectively giving themselves unlimited domain access. Golden Tickets persist even after password resets of other accounts because only resetting the KRBTGT password invalidates them.

Detection

- TGTs with unusual attributes: anomalous PAC contents, lifetimes exceeding 10 hours, tickets for non-existent users
- Microsoft Defender for Identity (MDI): Alerts on Golden Ticket indicators

Mitigation

- KRBTGT password must be reset TWICE (because AD maintains the previous hash) — coordinate carefully to avoid disruption
- Implement tiered AD administration model (Tier 0/1/2) to protect DC-level access
- Microsoft Advanced Threat Analytics / Defender for Identity for behavioral detection

9.5 Pass-the-Hash (PtH)

Attack Mechanics

Pass-the-Hash exploits the NTLM authentication protocol's design, which allows authentication using just the password hash rather than the plaintext password. If an attacker extracts NTLM hashes from memory (LSASS), SAM database, or ntds.dit, they can authenticate to any system accepting NTLM without knowing the actual password. PtH enables rapid lateral movement across Windows environments.

Detection

- Event ID 4624 (Logon Type 3/9) from anomalous source hosts
- LSASS access events (Sysmon Event 10) from non-system processes

Mitigation

- Credential Guard (virtualizes LSASS, prevents hash extraction), disable NTLM where possible, use Protected Users security group for privileged accounts, deploy Microsoft LAPS for unique local admin passwords

9.6 OAuth 2.0 / Token Abuse

Attack Mechanics

OAuth token attacks target the modern web application authentication layer. Adversaries register malicious OAuth applications and trick users into granting them access (consent phishing). Alternatively, attackers who compromise an endpoint steal access tokens from browser storage or memory to access cloud resources. The 2023 Microsoft Exchange breach (Storm-0558) used forged Azure AD access tokens to access customer email — a severe token abuse incident.

Detection

- Entra ID audit logs: New OAuth app consent events, unusual app permission grants
- Impossible travel or unusual API access patterns on application service principals

Mitigation

- Restrict user consent to pre-approved apps (admin consent workflow), enable Conditional Access for workload identities, implement Continuous Access Evaluation (CAE), rotate signing keys, use token binding

9.7 MFA Fatigue (Push Bombing)

Attack Mechanics

MFA fatigue targets push notification-based MFA (Duo, Okta Verify, Microsoft Authenticator). The attacker, possessing the victim's password, triggers repeated MFA push notifications, hoping the user approves one out of frustration or confusion. Uber's 2022 breach was initiated via MFA fatigue — a contractor approved an MFA push after repeated notifications and a social engineering call from the attacker claiming to be IT support.

Detection

- High volume of MFA push denials or timeouts from a specific user in a short window
- Unusual authentication times combined with MFA activity

Mitigation

- Enable number matching (user must enter a code shown on the sign-in screen into the authenticator app — prevents blind approval), additional context in push notifications (app name, geographic location), migrate to FIDO2/passkeys which are immune to this attack entirely

9.8 Cloud Privilege Escalation

Attack Mechanics

Cloud privilege escalation exploits overly permissive IAM roles and dangerous permission combinations to elevate access. Examples include: IAM user with `iam:PassRole` + `ec2:RunInstances` can launch an EC2 with a higher-privileged role; `iam:CreatePolicyVersion` can create a new policy version with Admin permissions; `lambda:CreateFunction` + `iam:PassRole` can create a Lambda with admin-level execution role. Scott Piper's 'AWS IAM Privilege Escalation Paths' documents over 20 escalation paths.

Detection

- CloudTrail: IAM API calls (`CreatePolicy`, `AttachRolePolicy`, `PassRole`) by non-IAM-admin identities
- AWS GuardDuty: Policy escalation and anomalous IAM activity detections

Mitigation

- IAM Access Analyzer, AWS Service Control Policies blocking dangerous permission combinations, permission boundaries for delegated admins, CSPM tools for IAM risk detection

SECTION 10 — COMPLIANCE, GOVERNANCE & AUDITING

10.1 IAM/PAM Compliance Framework Alignment

Framework	IAM/PAM Relevant Requirements	Key Controls
ISO 27001 (A.9)	Access control policy, user access management, privileged access, password management, review of user access rights	Access control policy, JML process, access reviews, privileged account management, authentication policy
NIST CSF / SP 800-53	PR.AC (Access Control): Identity management, authentication, authorization; AC-2 to AC-25 control families	Account management, least privilege, session controls, remote access, audit log retention
CIS Controls v8	Control 5 (Account Management), Control 6 (Access Control), Control 12 (Network Infrastructure)	Inventory of accounts, least privilege, admin account controls, MFA for admin access
SOC 2 (CC6)	Logical and physical access controls, authentication, authorization, provisioning, monitoring	Access provisioning, MFA, access review evidence, de-provisioning, PAM for privileged access
HIPAA (164.312)	Access control (§164.312(a)), Audit controls (§164.312(b)), Person authentication (§164.312(d))	Unique user identification, emergency access, automatic logoff, audit logging, encryption
PCI-DSS v4.0	Req 7 (Restrict access by business need), Req 8 (Identify users and authenticate access)	Unique IDs, MFA for admin/remote, password complexity, shared credential prohibition, privileged access review
GDPR (Art. 25/32)	Data protection by design, access controls, audit trails, breach notification readiness	Access logging, data minimization in access grants, right-to-erasure in identity systems, DPA-aligned access reviews

10.2 Audit Logging Requirements

Every IAM and PAM action must produce a detailed, tamper-evident audit log that answers: who did what, to which resource, when, from where, and with what result. Audit logs are the foundation of both security monitoring (SIEM detection) and compliance evidence (auditor review).

10.2.1 Minimum IAM Audit Events

- Authentication events: Success, failure, MFA challenge result, adaptive auth outcome
- Authorization events: Access granted, access denied, policy evaluation result
- Identity lifecycle: Account creation, modification, disablement, deletion, role assignment/removal
- Privileged access: Credential checkout, session start/end, session recording reference, privilege elevation
- Governance: Access review creation, decision (certify/revoke), campaign closure, SoD violation detected
- Administrative: IAM policy changes, role modifications, federation configuration changes

10.3 Access Review Evidence for Auditors

Compliance auditors require documented evidence that access is periodically reviewed and that inappropriate access is revoked. IGA platforms generate campaign completion reports showing: review scope, reviewer identity, decision per entitlement (certified/revoked), completion percentage, and remediation actions taken. These reports serve as primary evidence for SOC 2 CC6.3, ISO 27001 A.9.2.5, and PCI-DSS Requirement 7 controls.

- Maintain access review records for the retention period required by applicable frameworks (typically 1-7 years)
- Ensure review records are tamper-evident and stored in a compliance-designated repository
- Document exceptions: access certified despite concerns should include documented risk acceptance

SECTION 11 — IAM/PAM MANAGER TECHNICAL PLAYBOOK

11.1 Technical Skills for IAM/PAM Managers

IAM/PAM management is a deeply technical discipline. Effective managers must be hands-on enough to architect solutions, evaluate vendor capabilities accurately, direct engineering teams, and interpret security findings — while also operating at the executive level to drive program strategy, budget, and governance.

11.1.1 Core Technical Domains

Technical Domain	Required Competency Level	Practical Application
Identity Protocols	Deep (SAML, OIDC, OAuth 2.0, Kerberos, LDAP)	Evaluate IdP integrations, troubleshoot federation issues, assess protocol security risks
Cloud IAM	Advanced (AWS IAM, Azure RBAC/Entra, GCP IAM)	Review cloud posture, evaluate CIEM findings, direct cloud IAM architecture
PAM Architecture	Advanced (Vault, Proxy, Agent patterns)	Direct PAM program scope, evaluate PAM tool RFPs, oversee deployment
Directory Services	Intermediate-Advanced (AD, Entra ID, LDAP)	Understand hybrid identity architecture, oversee AD hardening
Zero Trust	Advanced (NIST ZTA, Conditional Access, device trust)	Drive ZTA roadmap, align IAM with enterprise security architecture
IGA/Governance	Advanced (lifecycle, SoD, certification)	Own access governance program, define policies, report to audit/compliance
Secrets Management	Intermediate (Vault, cloud secrets managers)	Oversee DevSecOps PAM strategy, evaluate secrets sprawl remediation
Compliance	Advanced (SOC 2, ISO 27001, PCI-DSS, HIPAA)	Own IAM compliance evidence, direct audit preparation
Threat Analysis	Intermediate (identity attack vectors)	Direct detection logic, evaluate ITDR platform, brief CISO on identity risks
Automation/IaC	Intermediate (Terraform, PowerShell, Python)	Evaluate automation maturity, oversee IAM-as-code initiatives

11.2 Operational Responsibilities

11.2.1 IAM Program Ownership

- Define and maintain the IAM and PAM program charter, scope, and strategy
- Own the identity security roadmap aligned with enterprise security strategy and risk appetite
- Chair the IAM governance committee; drive stakeholder alignment across IT, Security, HR, Legal, and Compliance
- Manage vendor relationships: CyberArk, SailPoint, Okta, Microsoft — contract renewals, escalations, roadmap input

11.2.2 Security Metrics and KPIs

KPI / Metric	Definition	Target
MFA Coverage	% of user accounts with MFA enforced	>99% (100% for privileged)
Privileged Account Coverage	% of privileged accounts under PAM control	>95%
Provisioning SLA Compliance	% of access requests fulfilled within SLA	>98%
De-provisioning SLA Compliance	% of terminations with access fully revoked within 4 hrs	>99%
Access Review Completion Rate	% of certification campaign items completed on time	>95%
Orphaned Account Rate	% of enabled accounts with no login activity in 90 days	<2%
Excessive Privilege Accounts	% of accounts with permissions exceeding role definition	<5%
PAM Session Coverage	% of privileged sessions captured with recording	>95%
Stale Privileged Access	% of PIM-eligible roles not activated in 90 days	<10%
Password Rotation Compliance	% of vaulted accounts with rotation within policy window	>98%
SoD Violation Rate	Open SoD conflicts as % of total entitlement assignments	<1%
FIDO2/Passkey Adoption	% of users enrolled in phishing-resistant MFA	>50% (target 100%)

11.2.3 IAM Incident Coordination

IAM/PAM managers must lead or closely coordinate identity-related security incidents. Key incident scenarios: account takeover (ATO), credential stuffing campaign, privileged credential compromise, AD domain compromise, cloud IAM privilege escalation, and insider threat access abuse.

- Own the 'identity lane' in the incident response process — account isolation, credential revocation, access log forensics
- Pre-authorize emergency PAM access (break-glass) procedures with documentation and post-incident review
- Maintain runbooks for common identity incidents: compromised user, compromised service account, OAuth token abuse
- Participate in tabletop exercises focusing on identity attack scenarios

11.3 IAM Team Structure

Role	Primary Responsibilities	Key Technical Skills
IAM Manager	Program ownership, strategy, stakeholder management, metrics reporting	All IAM/PAM domains; leadership; risk management; compliance
Identity Architect	IAM solution architecture, platform design, technical standards	Deep protocol knowledge, cloud IAM, Zero Trust, integration patterns
PAM Engineer	PAM platform deployment, vault management, session configuration, connector development	CyberArk/BeyondTrust, network protocols, scripting, PKI
IAM Engineer	IdP configuration, SSO integrations, MFA deployment, provisioning workflows	Okta/Entra ID, SAML/OIDC, SCIM, PowerShell/REST APIs
IGA Specialist	IGA platform management, access certification campaigns, role management	SailPoint/Saviynt, access governance, SoD rules, SQL/reporting
IAM Analyst	Access request fulfillment, audit evidence collection, day-to-day operations	AD, ITSM platforms, audit log analysis, compliance frameworks
Governance Specialist	IAM policy development, compliance alignment, access review facilitation	Risk management, compliance frameworks, policy writing, IGA platforms

11.4 IAM Policy Development

IAM/PAM managers must author, maintain, and enforce identity security policies. Core policies include: Identity and Access Management Policy, Privileged Access Management Policy, Password and Authentication Policy, Account Lifecycle Management Policy, Access Review and Certification Policy, and Remote Access Policy. Policies must be reviewed annually, approved by CISO/executive leadership, and enforced through technical controls — not just documentation.

SECTION 12 — AUTOMATION, AI & THE FUTURE OF IAM

12.1 AI-Driven Identity Security

Artificial intelligence is transforming identity security across multiple dimensions: anomaly detection, automated access recommendations, risk scoring, and threat response. AI models trained on identity behavior baselines can detect subtle deviations — a user downloading unusually large files at 2am, accessing systems they've never used, or lateral movement patterns — that rule-based SIEM detection misses.

- Microsoft Entra ID Identity Protection: ML-based sign-in risk and user risk scores, updated in real time
- Okta ThreatInsight: Aggregates threat signals across the Okta customer network for collective defense
- SailPoint AI Access Recommendations: ML-driven suggestions for role assignments and access reviews based on peer group analysis
- CyberArk Behavioral Analytics: Session command sequence analysis for privileged user anomaly detection

12.2 Identity Threat Detection and Response (ITDR)

ITDR is an emerging security category focused specifically on detecting, investigating, and responding to identity-based attacks. While traditional EDR focuses on endpoint telemetry and SIEM correlates across broad log sources, ITDR platforms specialize in identity signal — authentication logs, directory changes, privileged session activity, and cloud IAM events — to detect identity threats with higher fidelity and lower false positive rates.

- CrowdStrike Falcon Identity Threat Protection: Real-time AD and identity attack detection with automated response
- Microsoft Defender for Identity (MDI): On-premises AD attack detection (Kerberoasting, Golden Ticket, lateral movement)
- Vectra AI: Network and identity behavioral analytics with automated investigation
- Semperis Directory Services Protector: AD-focused threat detection and automated rollback of malicious changes

[i] ITDR is listed as a top security investment priority by Gartner and is increasingly being integrated with EDR and SIEM platforms for unified threat response.

12.3 Passwordless Future

The enterprise identity industry is in active transition away from passwords. Microsoft reports that over 99% of compromised accounts had no MFA; FIDO2/passkeys eliminate the phishable password entirely. The roadmap: MFA for all accounts (now) → Passwordless for new deployments (now) → Eliminate passwords for existing accounts (2-3 year program) → Password-free enterprise (target state).

12.4 Decentralized Identity and Verifiable Credentials

Decentralized Identity (DID) is an emerging paradigm where individuals control their own identity data, stored in a blockchain or distributed ledger, rather than relying on a centralized IdP. W3C Verifiable Credentials (VCs) allow trusted third parties to issue cryptographically signed attestations (age verification, employment, qualifications) that individuals can present without revealing underlying personal data. Microsoft Entra Verified ID implements W3C DID/VC standards for enterprise use cases: employee credential verification, partner access, and educational credential verification.

12.5 Behavioral Identity Analytics

Behavioral analytics extends risk scoring beyond static attributes to dynamic behavioral patterns: normal working hours, typical applications accessed, data volumes transferred, typing cadence, and navigation patterns. Continuous behavioral analysis creates a dynamic risk score that evolves throughout a session — enabling continuous authentication decisions without user friction. UEBA (User and Entity Behavior Analytics) platforms (Splunk UBA, Microsoft Sentinel UEBA) implement this at enterprise scale.

SECTION 13 — PRACTICAL IMPLEMENTATION GUIDE

13.1 Enterprise IAM/PAM Implementation Roadmap

A structured, phased approach to IAM/PAM implementation reduces risk, demonstrates early value, and builds organizational capability progressively. The following roadmap is designed for a medium-to-large enterprise with existing on-premises AD, mixed cloud presence, and limited existing IAM maturity.

Phase 1 — IAM Foundations (Months 1-3)

- Deploy centralized IdP (Okta or Entra ID) as the single authentication authority
- Establish HR-to-IdP provisioning integration via SCIM for automated JML processing
- Inventory all user accounts across AD, cloud, and applications — establish authoritative account baseline
- Implement password policy enforcement: minimum 12 characters, complexity, banned passwords
- Enable audit logging across all authentication systems; route to SIEM
- Disable/delete orphaned and dormant accounts identified in inventory
- Deliverables: IdP deployed, JML automation active, account inventory, audit logging baseline

Phase 2 — MFA and Federation (Months 3-6)

- Deploy MFA for all user accounts — prioritize admins and privileged users first
- Implement Conditional Access policies: block legacy auth, require MFA, require compliant device
- Federate SaaS applications (O365, Salesforce, ServiceNow) to IdP for SSO
- Deploy FIDO2/passkeys for high-risk roles (admins, executives, finance) as phase 2a
- Implement adaptive authentication and Identity Protection risk-based policies
- Deliverables: MFA for all users, SSO for top-20 applications, Conditional Access baseline

Phase 3 — PAM Deployment (Months 4-9)

- Deploy PAM vault (CyberArk, BeyondTrust, or Delinea) — start with crown jewel accounts
- Onboard domain admin, local admin, root, and service accounts to the vault
- Enable password rotation for onboarded accounts
- Configure session recording for all privileged RDP and SSH sessions
- Implement JIT access workflow via PAM (integrated with ITSM change management)
- Deploy LAPS or CyberArk EPM for local admin account management on endpoints
- Deliverables: PAM vault operational, top-50 privileged accounts onboarded, session recording active

Phase 4 — Governance and Automation (Months 6-12)

- Deploy IGA platform (SailPoint or Saviynt) with HR integration

- Build role model for top-5 business functions; implement role-based provisioning
- Launch first access certification campaign covering all privileged access
- Implement SoD rulebook and integrate into provisioning workflow
- Automate de-provisioning for leaver events: <4 hour SLA
- Implement secrets management for DevOps: HashiCorp Vault or AWS Secrets Manager
- Deliverables: IGA operational, first certification cycle complete, SoD enforcement active, secrets mgmt deployed

Phase 5 — Zero Trust Alignment (Months 9-18)

- Implement device compliance requirements in Conditional Access (Intune MDM enrollment)
- Deploy ITDR platform integrated with AD and cloud IdP
- Implement Workload Identity Federation for all CI/CD pipelines — eliminate static cloud credentials
- Extend FIDO2/passkeys deployment to all user population — passwordless program
- Implement network microsegmentation aligned with identity-based access policy
- Deploy CIEM tooling for cloud entitlement visibility across all cloud environments
- Deliverables: Device trust in Conditional Access, passwordless for 80%+ users, ITDR operational, cloud CIEM deployed

SECTION 14 — TOOLING ECOSYSTEM

14.1 IAM Platform Comparison

Platform	Type	Strengths	Weaknesses	Best For
Microsoft Entra ID	Cloud IdP	Native M365/Azure integration, Conditional Access, PIM, no additional cost for M365 E3/E5 tenants, breadth of integrations	Limited flexibility outside Microsoft ecosystem; Entra ID P2 licensing required for PIM/Identity Protection	Microsoft-centric enterprises; O365 deployments
Okta Workforce Identity	Cloud IdP	Best-in-class SSO breadth (7000+ app integrations), flexible MFA, excellent UX, strong lifecycle management	Premium cost; less native for Azure/AWS than Microsoft; PAM is separate product	Multi-cloud, cloud-first, or mixed-IdP enterprises
Ping Identity	Cloud/Hybrid IdP	Strong hybrid/on-prem support, flexible deployment, good for complex federation scenarios	More complex administration; smaller ecosystem than Okta/Microsoft	Enterprises with complex hybrid federation requirements
ForgeRock (Ping)	Cloud/Hybrid IdP	Open-source core (OpenAM), highly customizable, strong B2C	Higher implementation complexity; requires more internal expertise	Enterprises needing deep customization or large B2C programs

14.2 PAM Platform Comparison

Platform	Architecture	Strengths	Weaknesses	Best For
CyberArk PAM	Vault + Proxy + Agent	Market-leading vault depth, strongest enterprise capabilities, EPM agent, extensive API ecosystem	High implementation complexity; licensing cost; requires dedicated CyberArk expertise	Large enterprises with complex on-prem and cloud hybrid environments
BeyondTrust PAM	Vault + Proxy + Agent (EPM)	Strong endpoint privilege reduction, excellent remote support integration, AD bridge for Linux/Mac	Vault capabilities less mature than CyberArk for complex enterprise scenarios	Enterprises prioritizing endpoint privilege and remote support
Delinea (Thycotic + Centrify)	Vault + Proxy + Agent	Competitive pricing, strong server privilege management, good cloud suite	Smaller partner ecosystem; less depth for very large enterprise vault scenarios	Mid-market to enterprise with mixed OS and cost sensitivity
HashiCorp Vault	Secrets Manager + PKI	Developer-friendly, dynamic secrets, cloud-agnostic, strong Kubernetes support, open-source core	Not a full PAM solution (lacks session recording, workflow); requires significant operational expertise	DevSecOps, cloud-native workloads, secrets management

14.3 IGA Platform Comparison

Platform	Deployment	Strengths	Weaknesses	Best For
SailPoint IdentityNow	SaaS (cloud-native)	Market-leading IGA, 200+ connectors, strong AI access recommendations, excellent compliance reporting	Premium pricing; complex implementation for custom environments; SaaS model may concern data-sensitive orgs	Large enterprises with broad governance requirements
Saviynt Enterprise Identity Cloud	SaaS	Strong cloud access governance, converged IGA+PAM capabilities, excellent for GRC alignment	Smaller partner ecosystem than SailPoint; some features less mature	Cloud-heavy enterprises; organizations needing IGA + cloud entitlement governance
Microsoft Entra ID Governance	SaaS (Entra)	Native to Microsoft ecosystem, no additional platform for M365 shops, access packages, lifecycle workflows	Limited connector breadth outside Microsoft apps; less mature certification campaign management vs SailPoint	Microsoft-centric organizations; M365/Azure-only governance needs

14.4 Secrets Management Comparison

Platform	Strengths	Cloud Native	Best For
HashiCorp Vault	Dynamic secrets, PKI, encryption-as-a-service, k8s native, highly extensible, open-source + enterprise	Cloud-agnostic; runs anywhere	Multi-cloud, DevSecOps, Kubernetes, complex secrets workflows
AWS Secrets Manager	Native AWS integration, automatic rotation for RDS/Aurora, simple API, tight IAM integration	AWS native	AWS-native organizations; database credential rotation
Azure Key Vault	HSM backing (Premium), Azure AD integration, tight Azure service integration, certificate management	Azure native	Azure-centric organizations; certificate and key management
CyberArk Conjur	Enterprise-grade, integrated with CyberArk PAM ecosystem, strong Kubernetes support	Cloud-agnostic	Enterprises already using CyberArk PAM needing unified PAM+secrets

References

- Amazon Web Services. (2025). AWS Identity and Access Management (IAM) Documentation. Retrieved from <https://docs.aws.amazon.com/iam/>
- BeyondTrust. (2025). Privileged Access Management Best Practices Guide. Retrieved from <https://www.beyondtrust.com>
- Center for Internet Security (CIS). (2025). CIS Controls Version 8. Retrieved from <https://www.cisecurity.org>
- CyberArk. (2025). Privileged Access Management and Identity Security Resources. Retrieved from <https://www.cyberark.com>
- FIDO Alliance. (2025). FIDO2: Moving the World Beyond Passwords. Retrieved from <https://fidoalliance.org>
- Gartner Research. (2024–2025). Identity and Access Management, Identity Governance, and Privileged Access Management Research Publications.
- Google Cloud. (2025). Google Cloud Identity and Access Management Documentation. Retrieved from <https://cloud.google.com/iam>
- HashiCorp. (2025). Vault Documentation. Retrieved from <https://developer.hashicorp.com/vault>
- International Organization for Standardization (ISO). (2022). ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems.
- Microsoft. (2025). Microsoft Entra ID Documentation. Retrieved from <https://learn.microsoft.com/en-us/entra>
- Microsoft. (2025). Microsoft Entra Privileged Identity Management Documentation. Retrieved from <https://learn.microsoft.com>
- National Institute of Standards and Technology (NIST). (2020). Special Publication 800-207: Zero Trust Architecture.
- National Institute of Standards and Technology (NIST). (2024). Digital Identity Guidelines (SP 800-63 Series).
- NIST National Cybersecurity Center of Excellence (NCCoE). (2024). Enterprise Identity and Access Management Guidance.
- Okta. (2025). Okta Identity Cloud Documentation. Retrieved from <https://developer.okta.com>
- OpenID Foundation. (2025). OpenID Connect Core 1.0 Specification. Retrieved from <https://openid.net>
- OWASP Foundation. (2025). OWASP Identity and Access Management Cheat Sheet. Retrieved from <https://cheatsheetseries.owasp.org>
- PCI Security Standards Council. (2024). PCI DSS Version 4.0.
- SailPoint Technologies. (2025). Identity Governance and Administration Resources. Retrieved from <https://www.sailpoint.com>

- Saviynt. (2025). Enterprise Identity Cloud Documentation. Retrieved from <https://saviynt.com>
 - The FIDO Alliance and World Wide Web Consortium (W3C). (2025). Web Authentication (WebAuthn) Specification.
 - Verizon. (2024). Data Breach Investigations Report (DBIR).
 - World Wide Web Consortium (W3C). (2025). Web Authentication API (WebAuthn). Retrieved from <https://www.w3.org>
 - Cloud Security Alliance (CSA). (2024). Security Guidance for Critical Areas of Cloud Computing.
 - MITRE ATT&CK Framework. (2025). Enterprise ATT&CK Knowledge Base. Retrieved from <https://attack.mitre.org>
 - CISA. (2025). Identity and Access Management Best Practices. Retrieved from <https://www.cisa.gov>
-

THE COMPLETE ENTERPRISE IAM & PAM MASTER GUIDE

Identity & Access Management | Privileged Access Management | Modern Identity Security

This guide is intended for professional development and enterprise implementation reference.